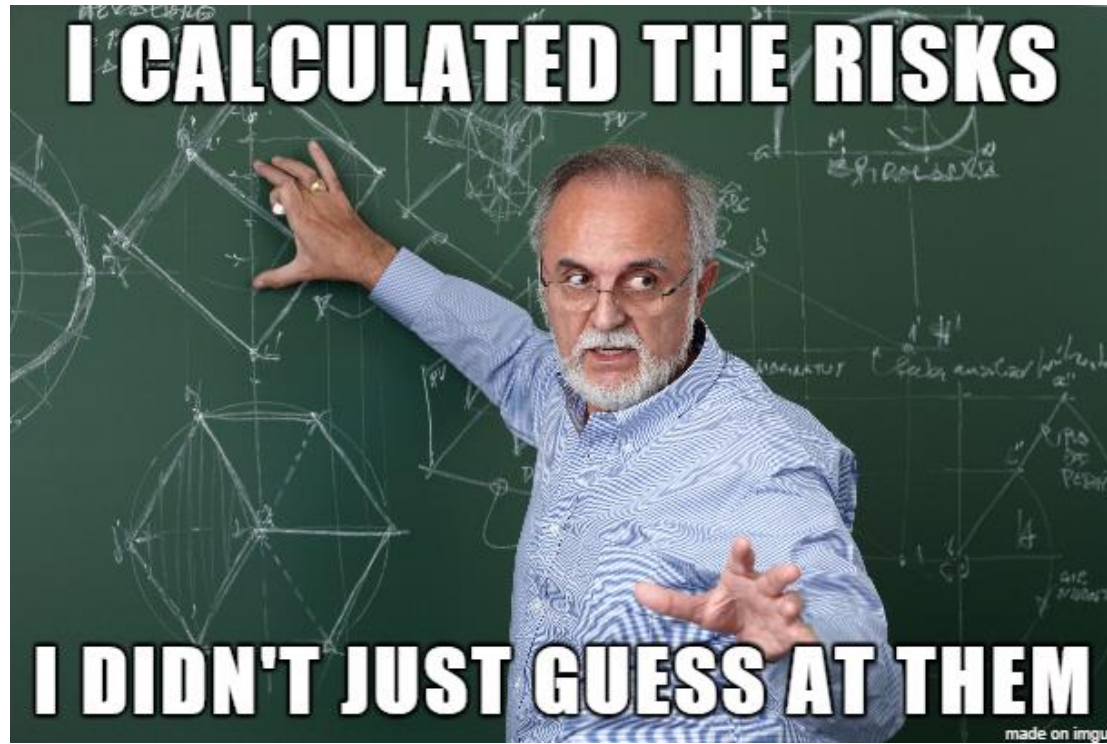


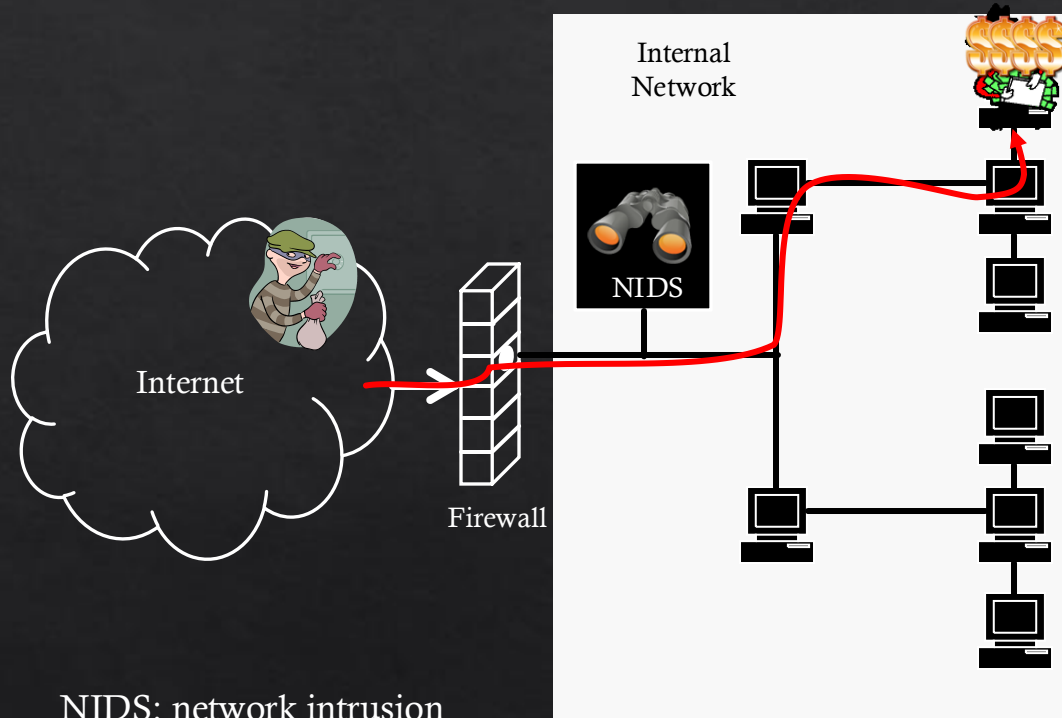


8. Security Modelling and Analysis

Jin Hong

jin.hong@uwa.edu.au

How secure is my system/network?



NIDS: network intrusion
detection system

How to assess security?



IT Security Management

- ◇ Related tasks for IT security management include
 - ◇ Specification of security objectives, strategies and policies
 - ◇ Determine organisational IT security requirements
 - ◇ Security threat assessments of IT assets and risks
 - ◇ Specification of appropriate security methods
 - ◇ Implementation and maintenance of security methods
 - ◇ Security awareness program and adoption
 - ◇ Detection and prevention of security incidents

Security Assessment

- ◆ Some key questions to answer in security assessment are:
 - ◆ How to represent and capture various **attack scenarios**?
 - ◆ What kinds of attacks are applicable?
 - ◆ How can these attacks be carried out?
 - ◆ How do we measure their impact on the system?
 - ◆ How to select the **best security solutions** and controls?
 - ◆ What is the best security practice for the given attack scenario?
 - ◆ What is the best security solution given these constraints?

Security Assessment

- ◇ Three main approaches

- ◇ Test on a real network

- Realistic Result
- Low Cost
- Time-consuming
- Disruption of Service

- ◇ Test on a duplicated real network

- ◇ E.g., Emulation

- Realistic Result
- High Cost
- Time-consuming
- No Disruption

- ◇ Model-based Security Assessment

- Model-dependant Result
- Low Cost
- Time-efficient
- No Disruption

- ◇ etc

Use of Security Models

- ◇ Security models can be used to provide a **systematic approach** to assess the security of systems
- ◇ Security models are one aspect of the security assessment, which requires 3M
 - ◇ **Security Measures** : To collect required information
 - ◇ **Security Metrics** : To represent the analysis results
 - ◇ **Security Models** : To capture security information of the system

Security Measurement

- ◇ What do we want to measure?
 - ◇ Vulnerabilities and their scores
 - ◇ Common Vulnerability and Exposures (CVE)
 - ◇ Common Vulnerability Scoring System (CVSS) Base Score (BS): e.g., 9 out of 10.
 - ◇ Reachability
 - ◇ Nmap (network mapping)
 - ◇ Network Configurations (e.g., access control by firewalls)
 - ◇ Mitigations
 - ◇ Detection (Intrusion Detection, Vulnerability Identification, ...)
 - ◇ Countermeasure (Patch, firewall rules changes, ...)



Security Metrics



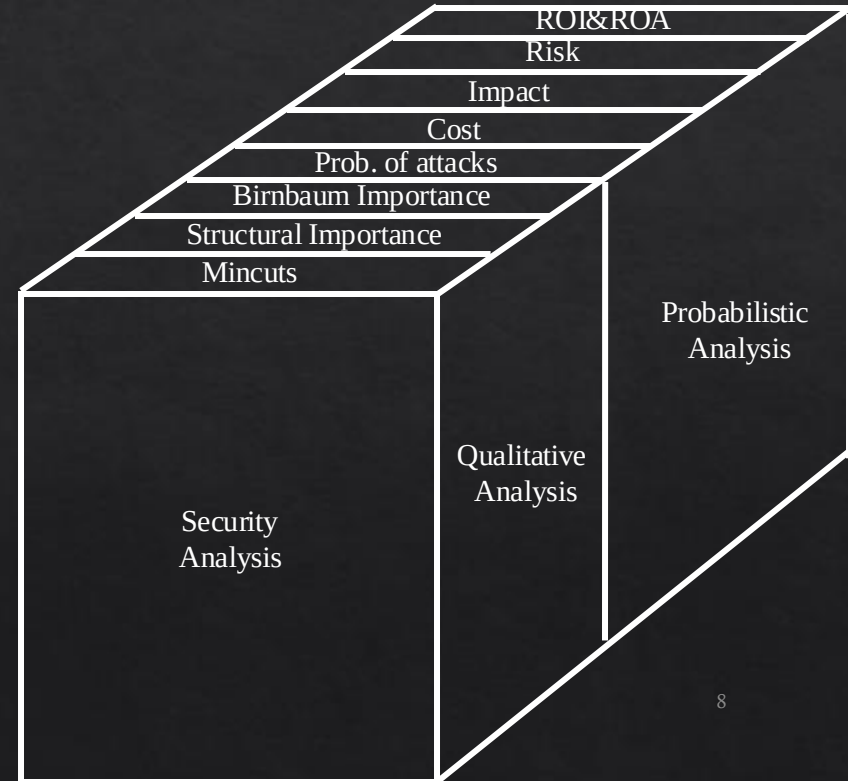
◆ What can we measure?

◆ Qualitative Analysis (Metrics)

- ◆ Mincuts (Attack countermeasure scenarios)
- ◆ Importance Measures
- ◆ ...

◆ Quantitative Analysis (Metrics)

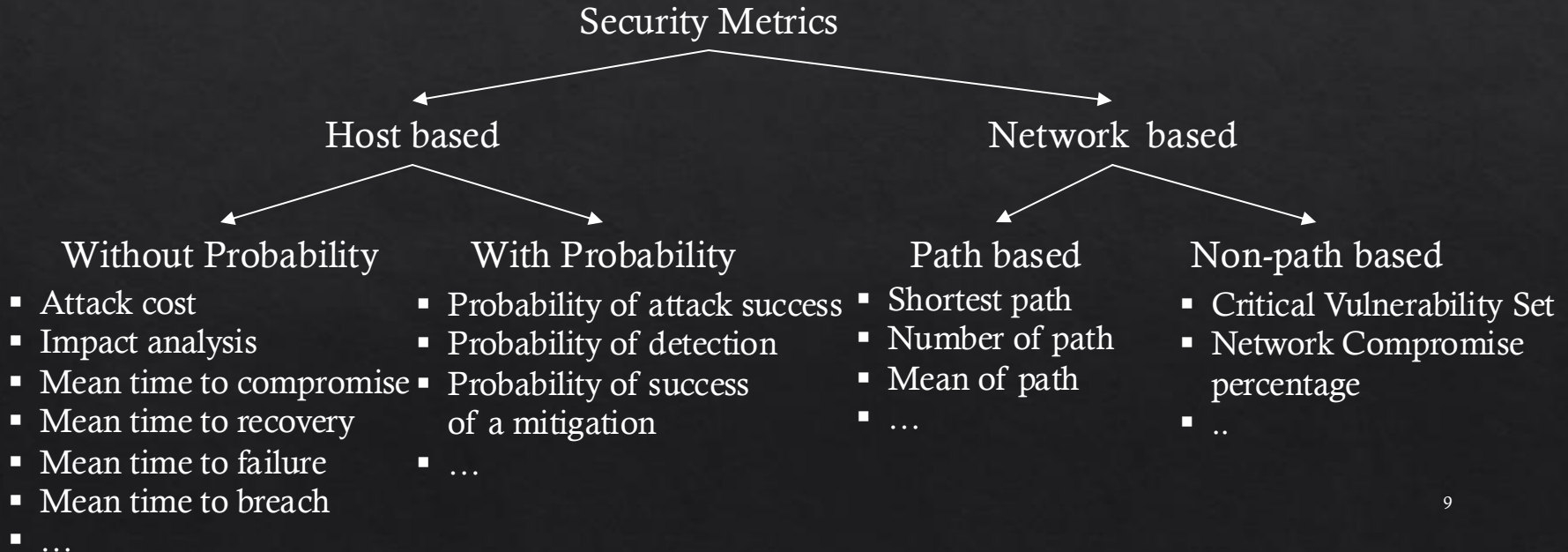
- ◆ Probability of Attacks
- ◆ Adversary's viewpoint
 - ◆ Cost of Attack
 - ◆ Return on Attack (ROA)
- ◆ Defender's Viewpoint
 - ◆ Risk = Prob.*Impact
 - ◆ Security Investment Cost
 - ◆ Return on Investment (ROI)
 - ◆ ...



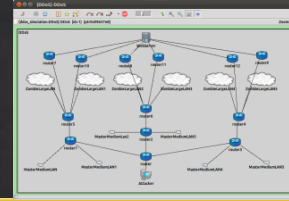
Security Metrics



◇ Other way to categorise security metrics:



Security Models



Security Models

**Tree
based**

Attack
Trees

Defense
Trees

...

Attack
Countermeasure
Trees (ACT)

**Graph
based**

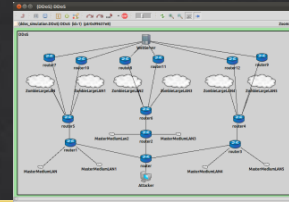
Attack
Graphs

...

Hybrid

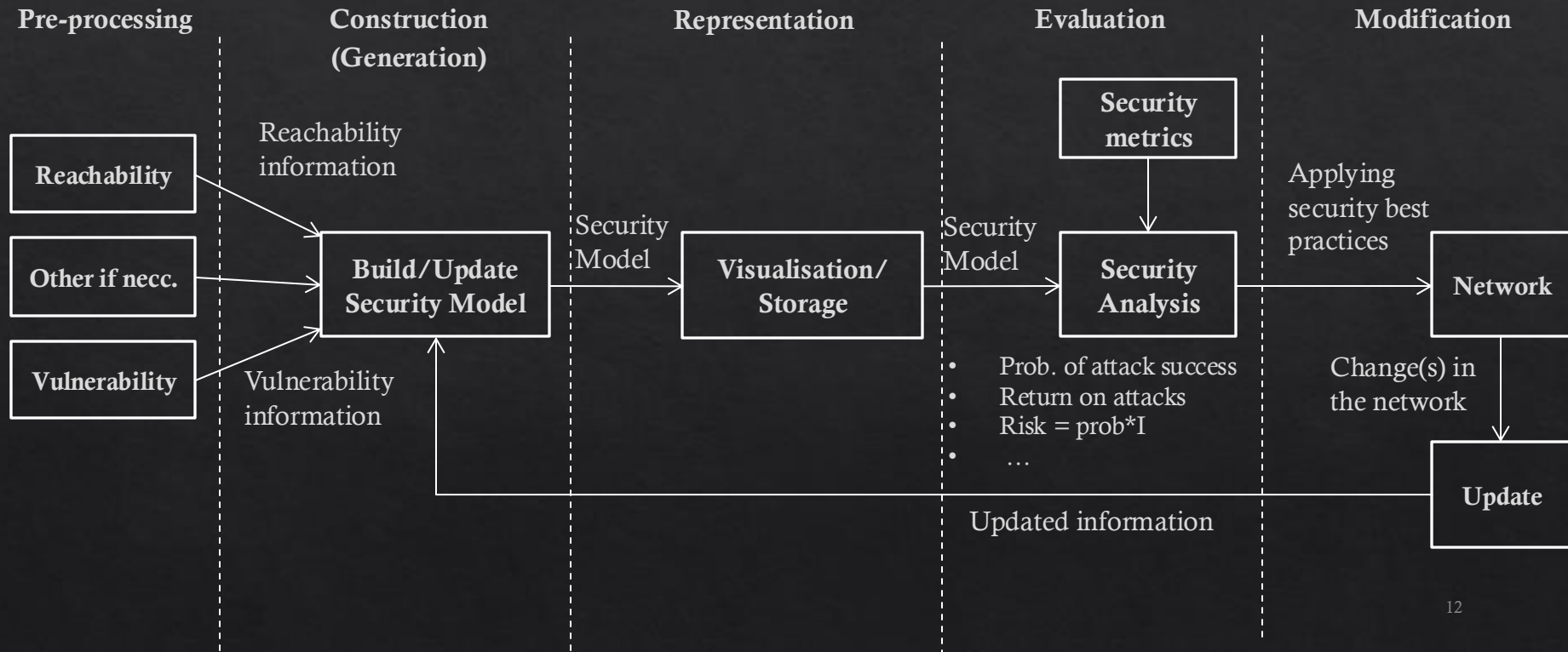
Hierarchical Attack
Representation
models (HARMs)

Security Models



- ◇ Security models can...
 - ◇ Capture and analyse attack scenarios
 - ◇ Perform automated security analysis
 - ◇ Compute optimal countermeasures
 - ◇ Use various security metrics

Security Model Lifecycle



Attack Trees

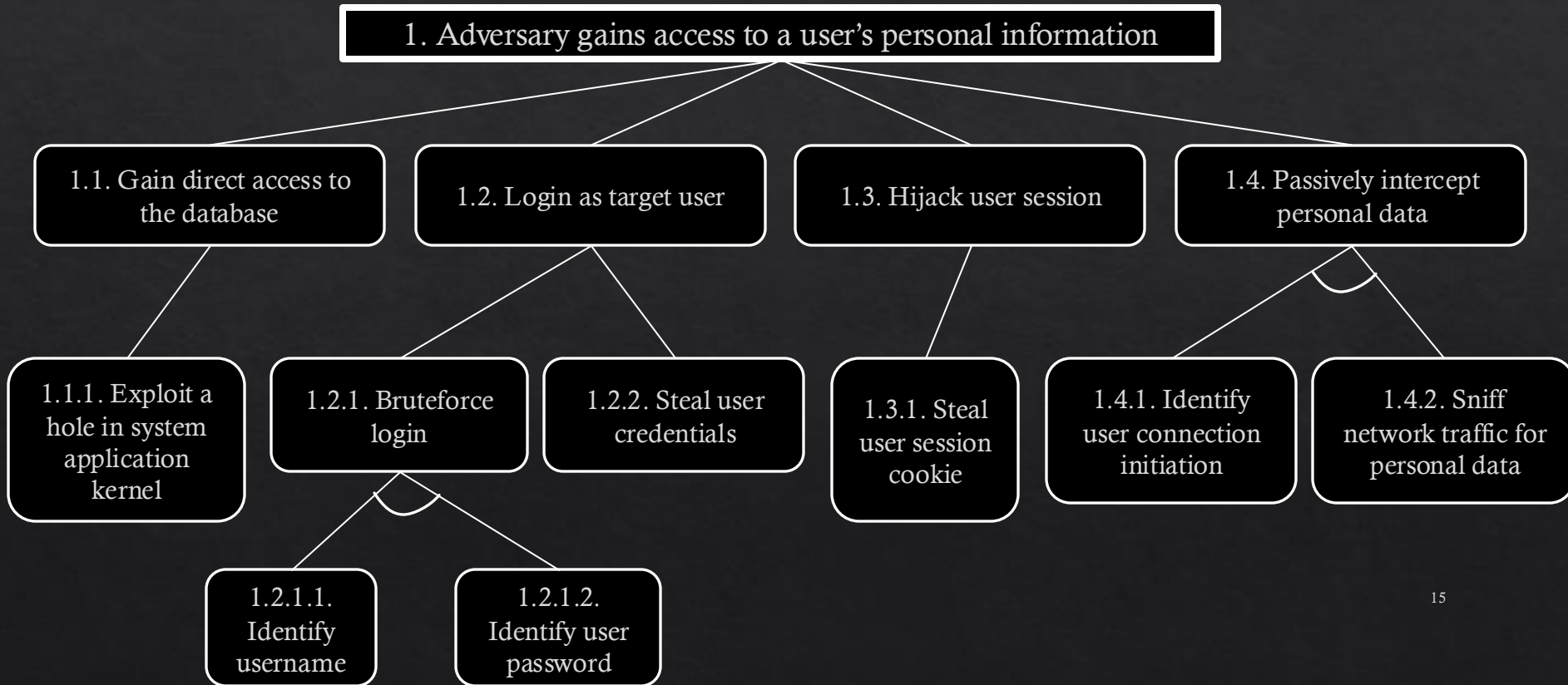
- ◇ Let us take a look at an Attack Tree (AT)
- ◇ ATs can
 - ◇ describe security of systems and subsystems
 - ◇ Specify and decompose attack goals and steps to achieve it
 - ◇ Evaluate the severity of different vulnerabilities in the system
 - ◇ Helps making decision to improve security

Attack Trees

◇ Structure

- ◇ Represent the attacks and countermeasures as a tree structure
- ◇ Root node is the goal of the attack
- ◇ Leaf nodes represents (atomic) attacks
- ◇ Uses logical gates to connect different attack events
 - ◇ E.g., uses of AND or OR gates
 - ◇ Attacker needs a swipe card AND pin number
 - ◇ Attacker needs to pick the lock OR break a window

Attack Trees



Attack Trees

1. Adversary gains access to a user's personal information

OR 1.1 Gain direct access to the database

1.1.1 Exploit a hole in system application or kernel

1.2 Log in as target user

OR 1.2.1 Brute-force login

AND 1.2.1.1 Identify username

1.2.1.2 Identify user password

1.2.2 Steal user credentials

1.3 Hijack user session

1.3.1 Steal user session cookie

1.4 Passively intercept personal data

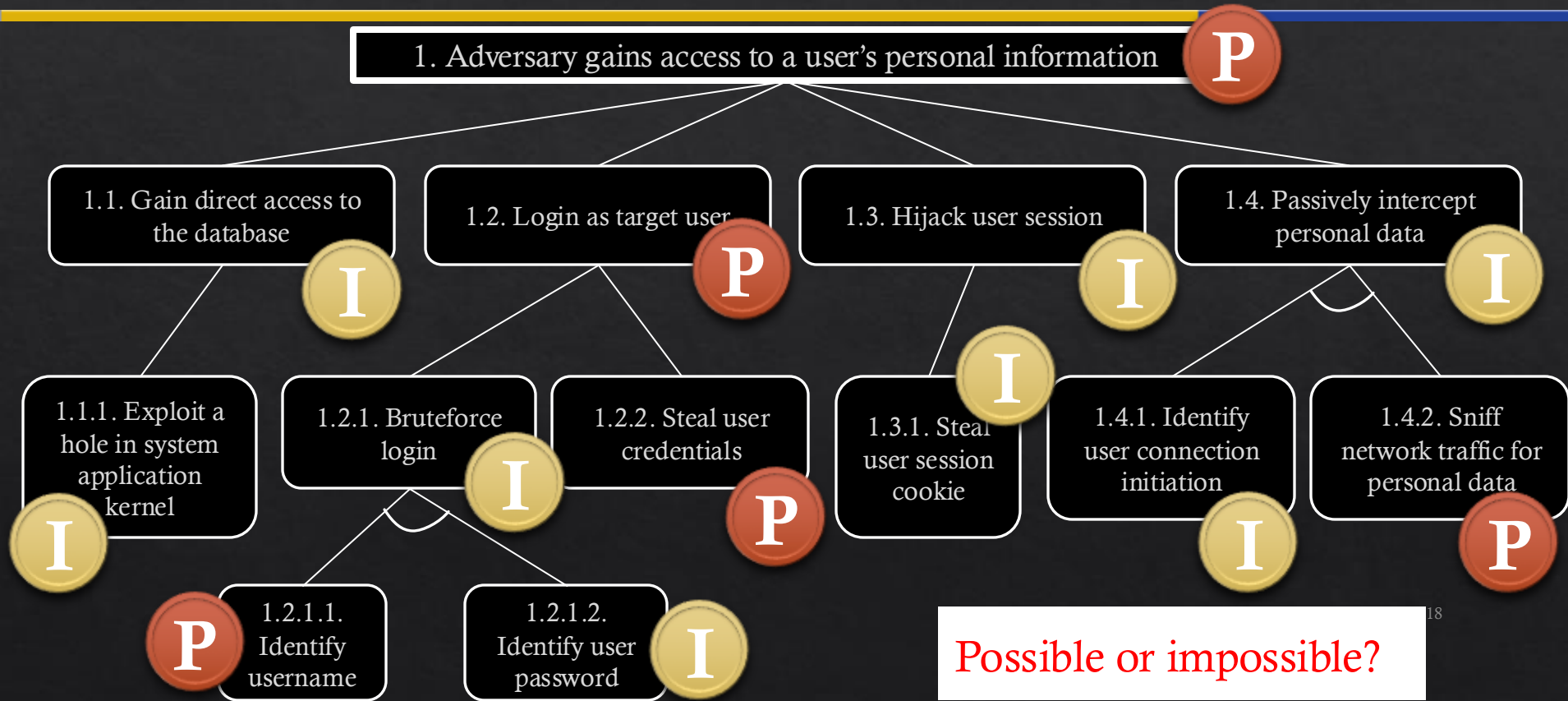
AND 1.4.1 Identify user connection initiation

1.4.2 Sniff network traffic for personal data

Attack Trees

- ◆ Leaf nodes can be assigned values to evaluate ATs
 - ◆ Boolean [e.g., possible/impossible]
 - ◆ Continuous [e.g., cost in \$, time]
 - ◆ Other [e.g., probability, impact, risk]
 - ◆ Combined [e.g., cheapest attack with high probability]

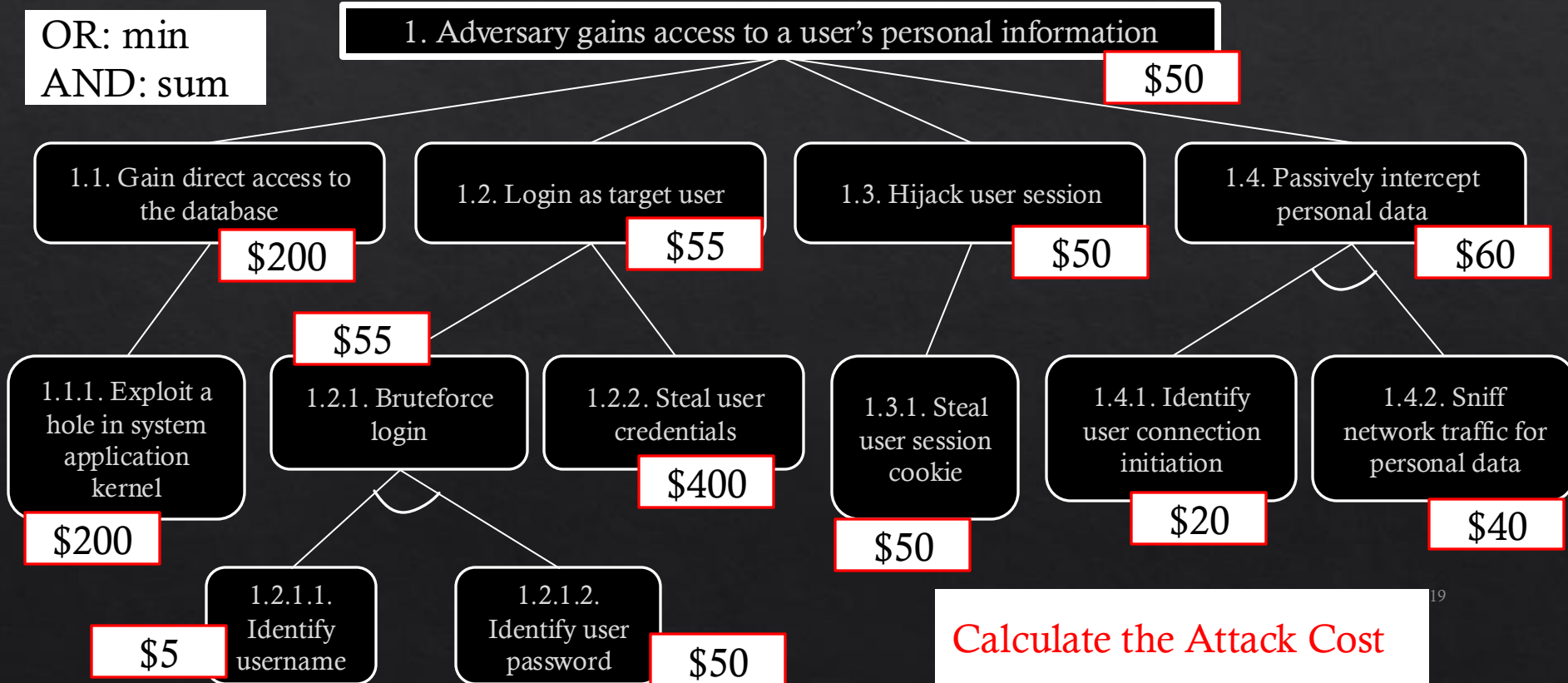
Attack Trees



Possible or impossible?

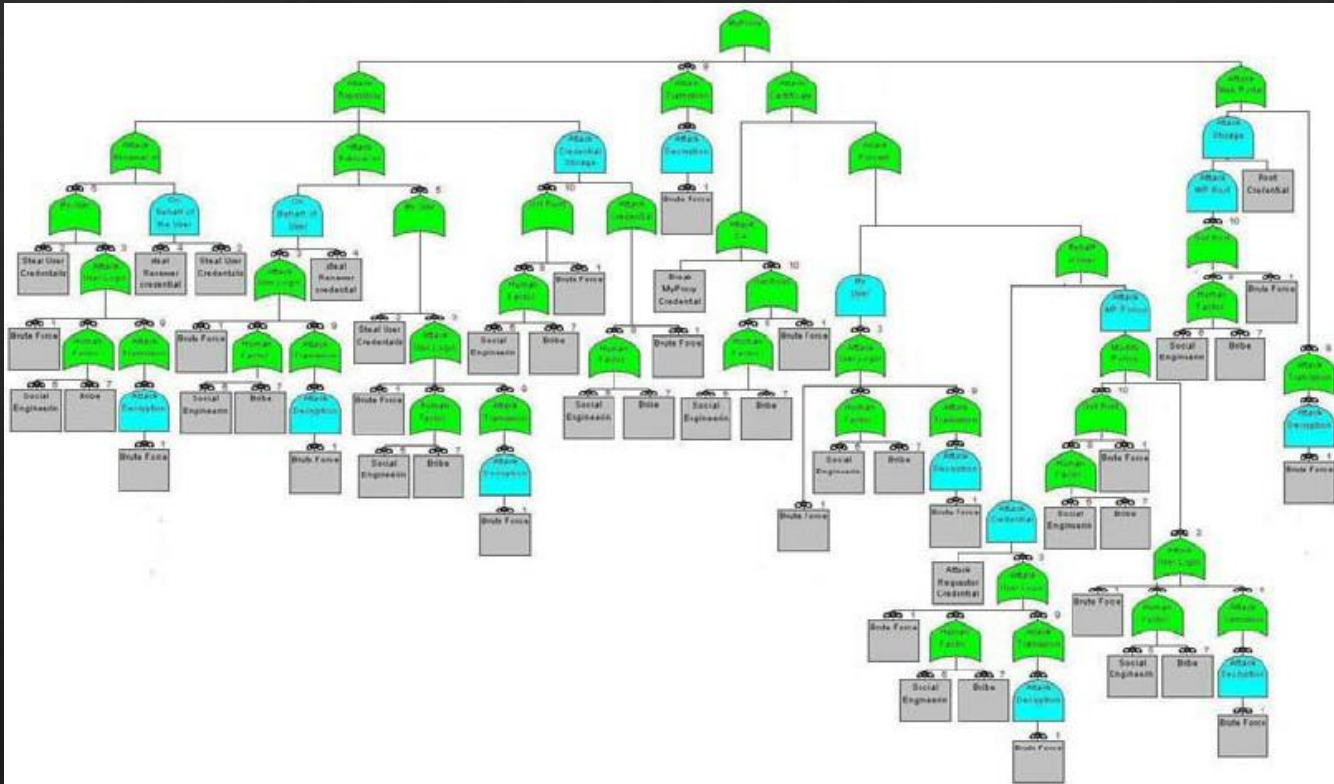
Attack Trees

OR: min
AND: sum



Calculate the Attack Cost

Attack Trees



Attack Trees

- ◇ Computations become more complex when using different types of gates for joining leaf nodes
 - ◇ Sequential AND, k-out-of-n gates etc...
- ◇ Many variants of the ATs
 - ◇ Protection Trees, Defense Trees, Attack Countermeasure Trees etc...
- ◇ There are various tools to generate ATs
 - ◇ SeaMonster
 - ◇ AttackTree+ (commercial)
 - ◇ SecuITree (commercial)
 - ◇ ATSyRa
 - ◇ Attack Navigator

Attack Tree exercise

- ◆ Given the scenario

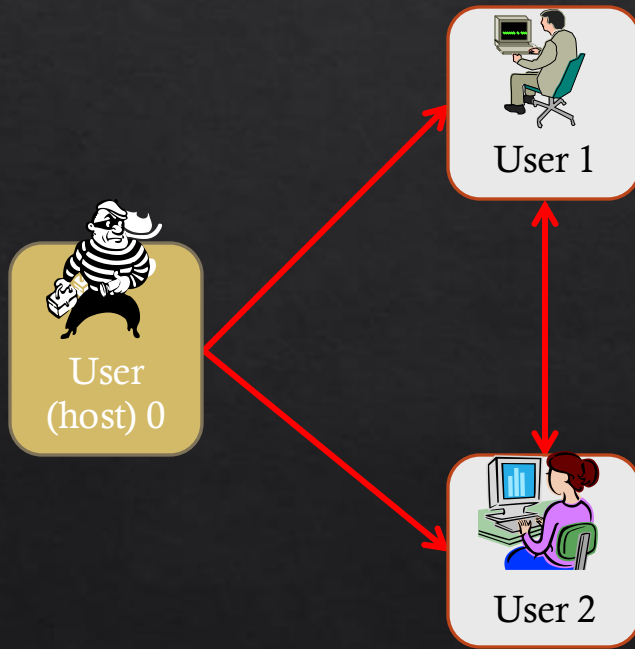
An attacker wants to compromise the Airport Control System (ACS) to manipulate the flight information. The ACS communicates with incoming and outgoing airplanes using its own wireless communication protocol (i.e., a non standard one). ACS also communicate with the airport staff, allowing authenticated staffs to check the status of all incoming and outgoing airplanes. Lastly, the ACS is connected to the internet to receive weather forecast, and notify any delays to the airport's website based on the weather.

- ◆ Identify the attack goal and construct an Attack Tree with at most six nodes for the given attack goal.

Attack Graphs

- ◇ Similar technique to ATs
- ◇ Unlike ATs, AGs may have cyclic dependencies or merged states
 - ◇ State transition information
 - ◇ Order of events
 - ◇ Etc.

Attack Graphs

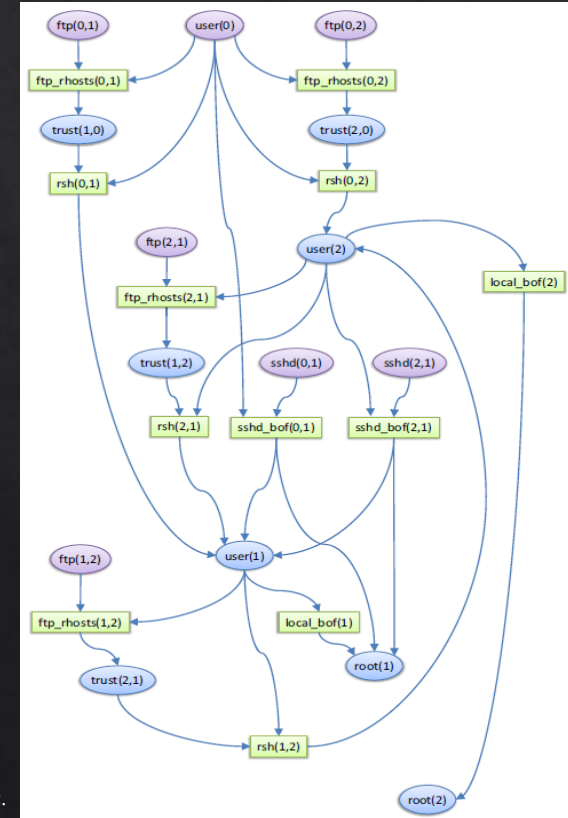


Vulnerabilities:

- ftp_rhosts
- rsh
- sshd_BoF
- local_BoF

Vulnerabilities:

- ftp_rhosts
- rsh
- local_BoF



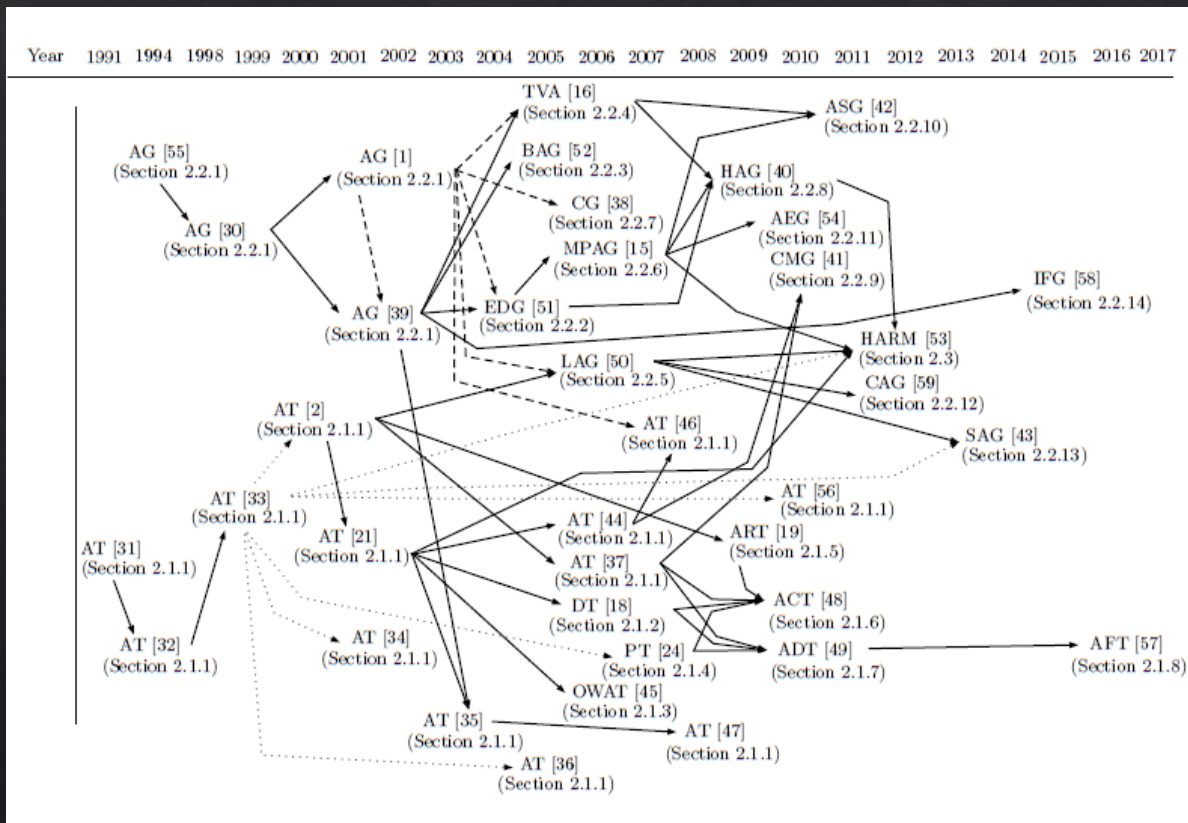
Attack Graphs

- ◇ Many variants of the AGs
 - ◇ Logical AGs, Bayesian AGs, Multiple prerequisite AGs, etc...
- ◇ There are tools available to generate AGs
 - ◇ NuSMV
 - ◇ RedSeal (commercial)
 - ◇ Skybox (commercial)
 - ◇ Cauldron (commercial)
 - ◇ CyGraph

What type do you use?

- ◇ Depends on various factors
 - ◇ What metrics can I use?
 - ◇ How efficient is the security assessment?
 - ◇ What tools are available?
 - ◇ What type of attacks can it model?
 - ◇ Which systems can I use the model?
 - ◇ Etc...

Evolution of Graphical Security Models (GSMs)



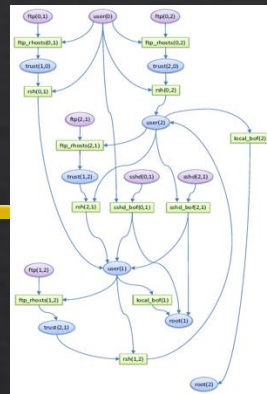
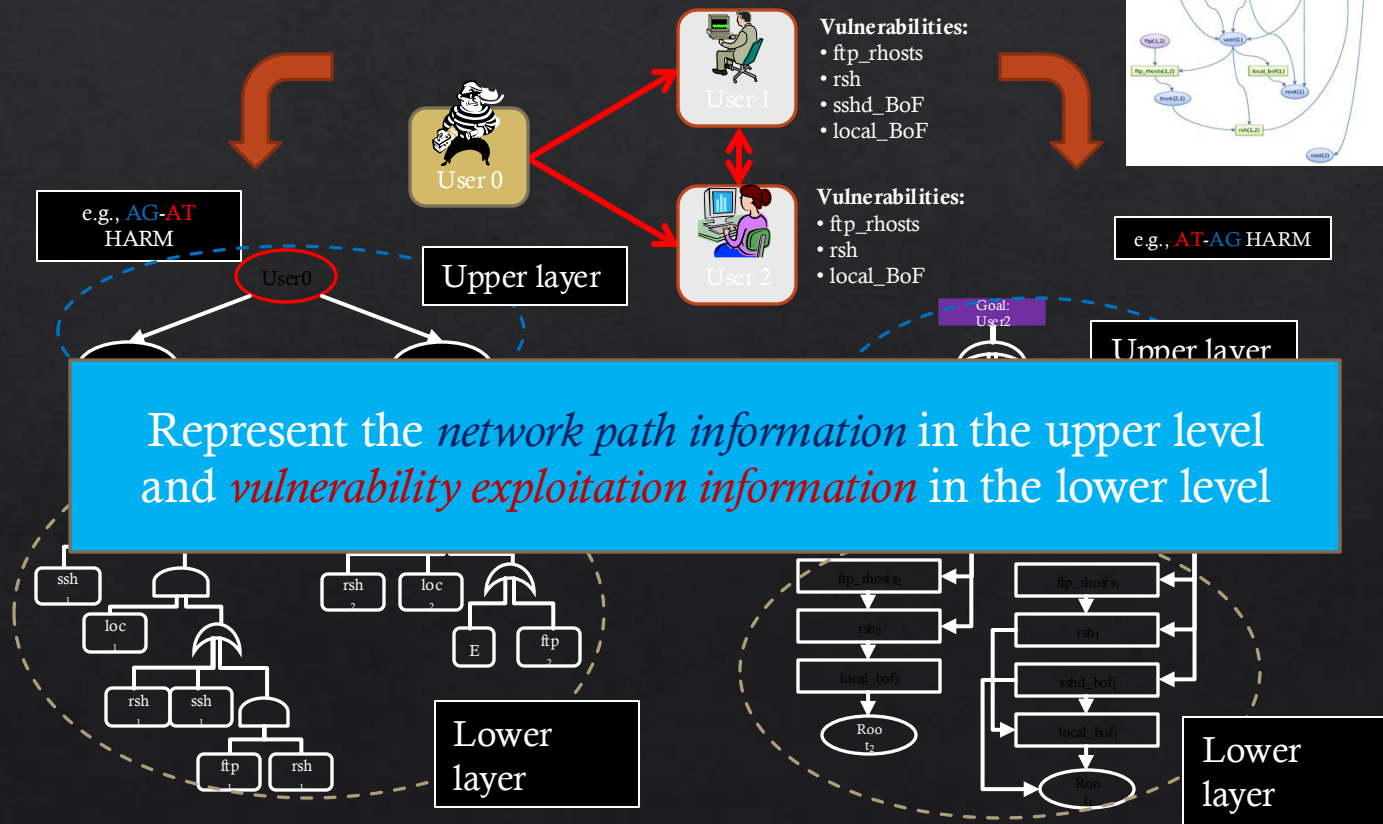
Limitations

- ◇ Scalability issues
 - ◇ The generation of full attack models and evaluation of all possible attack scenarios exhibit a **state-space explosion**
- ◇ Dynamic adjustment (Adaptability) issues
 - ◇ A change in the network system **causes updates** in the security model
- ◇ Automating security decisions and countermeasure selections issues
 - ◇ Requires intelligent **security decision making** and **real-time adaptation and deployment** of security solutions.

Limitations

- ◆ To address the scalability issues
 - ◆ Adopt new modelling techniques
 - ◆ E.g., using hierarchy, etc...
 - ◆ Implement efficient generation and evaluation algorithms
 - ◆ E.g., heuristic, dynamic programming solutions, etc...
 - ◆ Anything else?
 - ◆ E.g., subgraph evaluation, parallel computing

Approach 1: Hierarchy



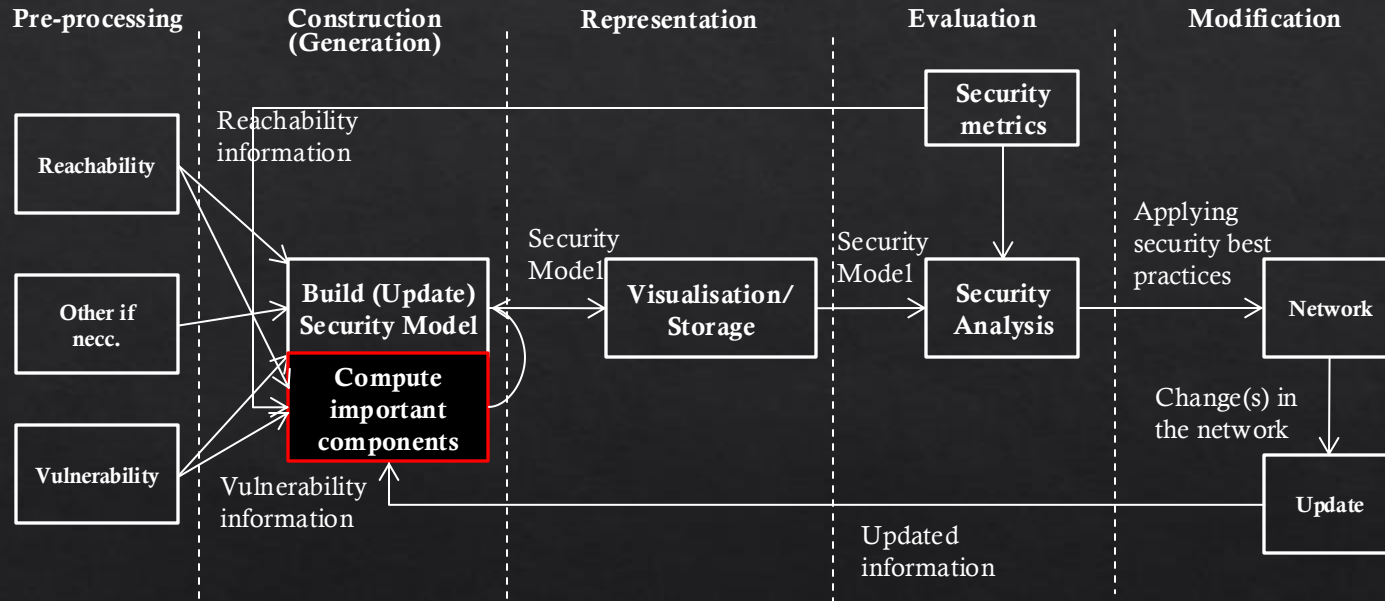
Approach 2: Importance Measures

- ◇ When analysing network security, there are only a **subset** of network components that have a critical role in an event of an attack.
- ◇ **All** network components are considered when the GSMs are constructed.
- ◇ To **improve** the performance of both construction and evaluation phases of GSMs, we consider to use only important hosts and vulnerabilities.

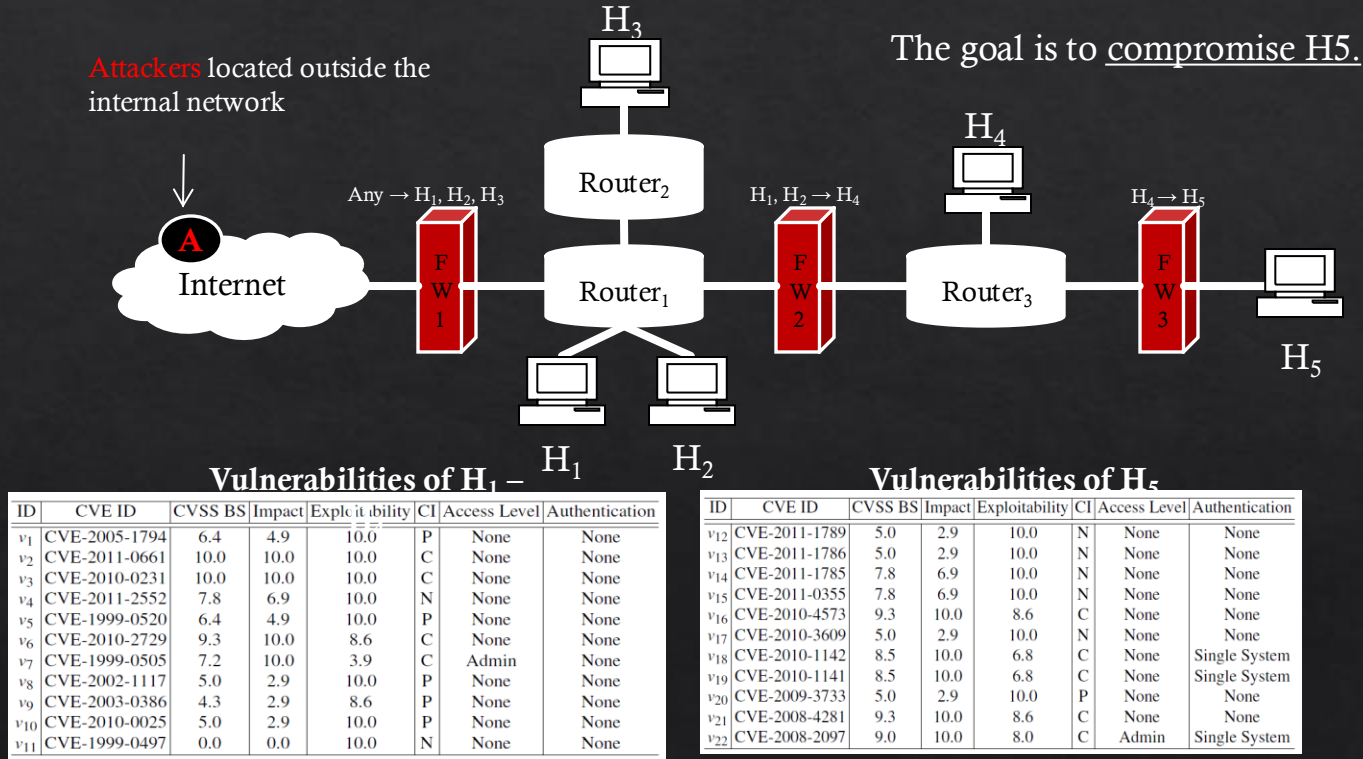
Use Importance Measures



Recap – Lifecycle of Graphical Security Models



An Example Networked System



using vulnerability scanners such as **NESSUS**

Ranking hosts

◇ Ranking Hosts w.r.t NCMs

	Degree	Closeness	Betweenness	Rank Sum	Final Rank
H_4	3/4	4/5	10/12	3	1
H_1	3/4	4/5	8/12	4	2
H_2	3/4	4/5	8/12	4	2
H_3	2/4	4/7	4/12	12	4
H_5	1/4	4/12	4/12	14	5

We combine all NCMs to formulate the final rank

- For our example, each rank acted as a score to give the final rank (i.e., scores are used to re-rank nodes)
- Rankings from each NCM are used as the importance score

Ranking vulnerabilities on hosts

◇ Ranking Vulnerabilities

Vulnerabilities of $H_1 - H_4$



	v_2	v_3	v_6	v_4	v_7	v_1	v_5	v_8	v_{10}	v_9	v_{11}
CVSS BS	10.0	10.0	9.3	7.8	7.2	6.4	6.4	5.0	5.0	4.3	0.0
Rank	1	1	3	4	5	6	6	8	8	10	11

Vulnerabilities of H_5



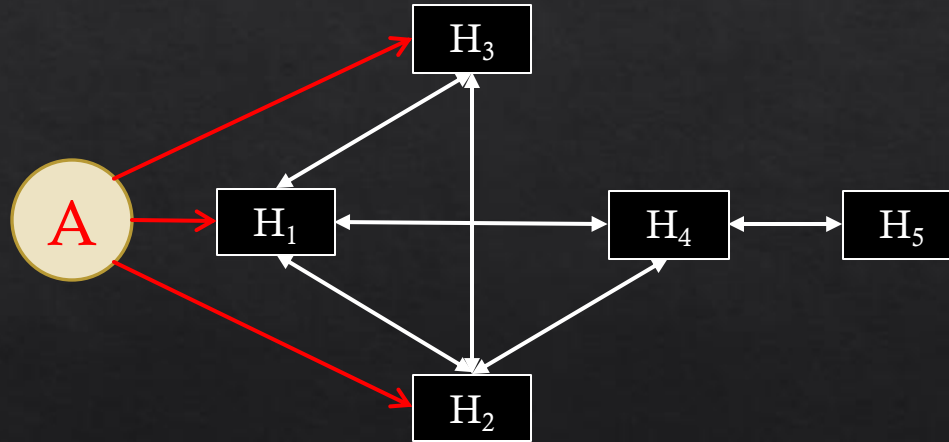
	v_{16}	v_{21}	v_{22}	v_{18}	v_{19}	v_{14}	v_{15}	v_{12}	v_{13}	v_{17}	v_{20}
CVSS BS	9.3	9.3	9.0	8.5	8.5	7.8	7.8	5.0	5.0	5.0	5.0
Rank	1	1	3	4	4	6	6	8	8	8	8

Vulnerabilities are ranked based on their CVSS BSs

Important vulnerabilities are selected based on the threshold value
(e.g., higher than the average CVSS BS)

Full HARM

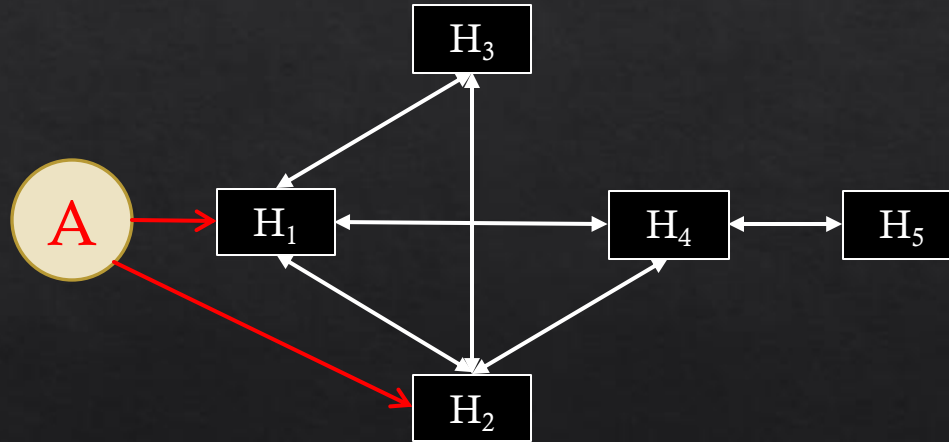
◇ The upper layer



Upper layer (AG)

Simplified HARM

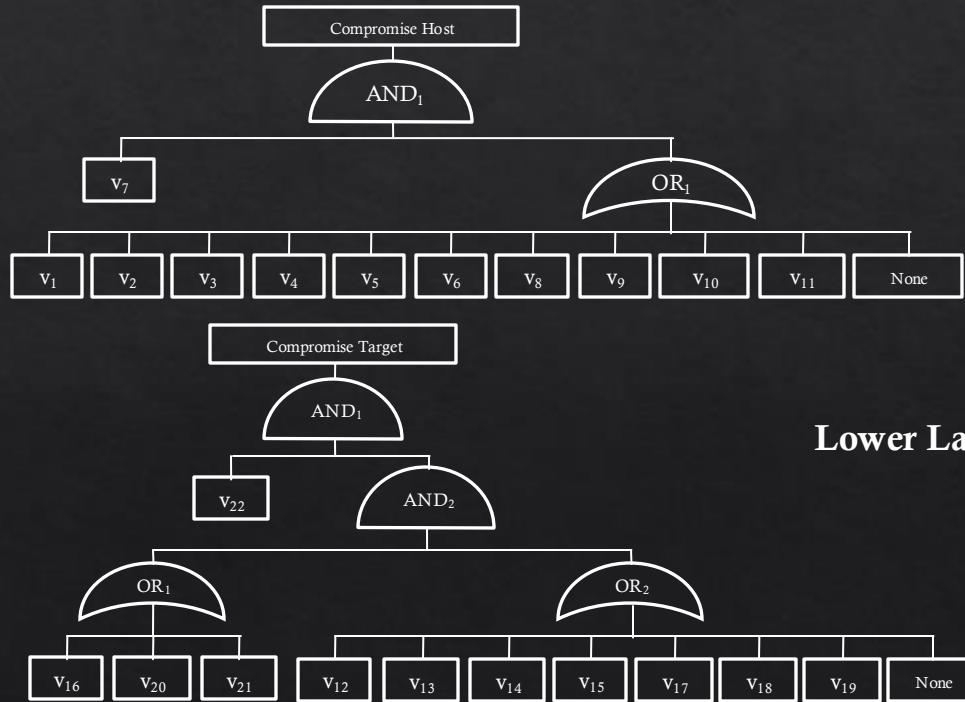
- ◇ The upper layer: Using only important **hosts**



Upper layer (AG)
Using 3 hosts

Full HARM

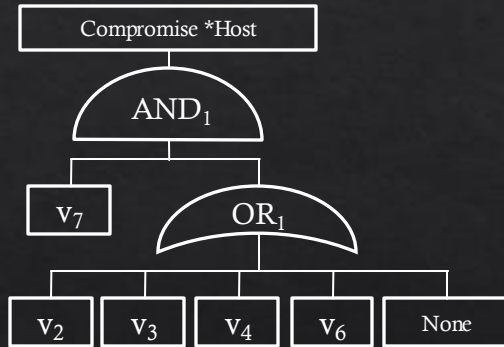
◇ The lower layer



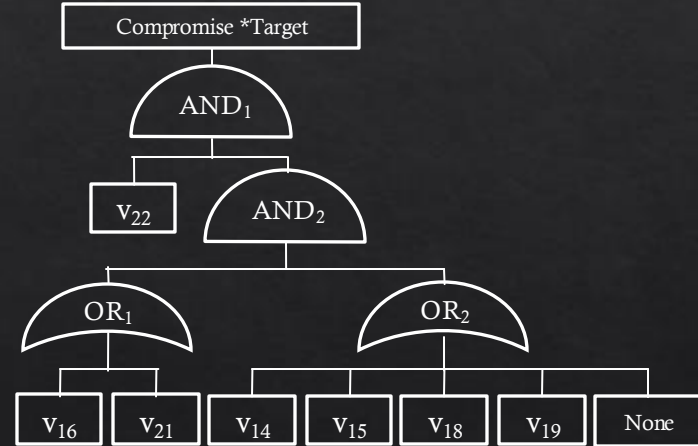
Lower Layer (AT)

Simplified HARM

- ◆ The lower layer: using Important **vulnerabilities**



Using 5 vulnerabilities

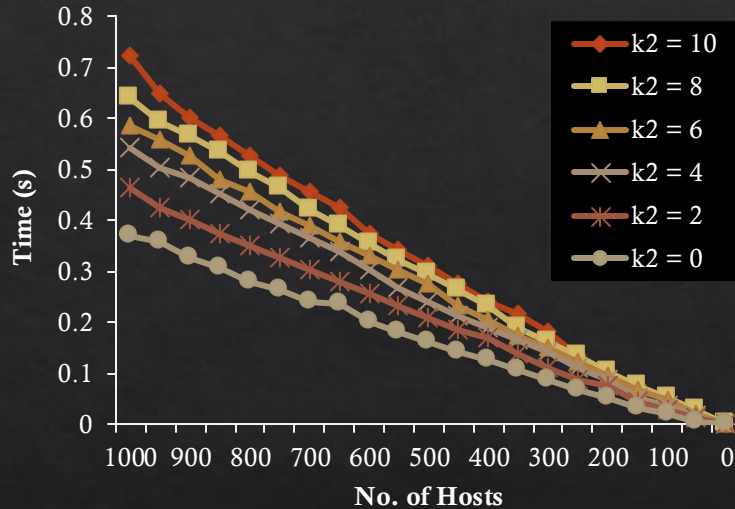


Using 7 vulnerabilities

Lower Layer (AT)

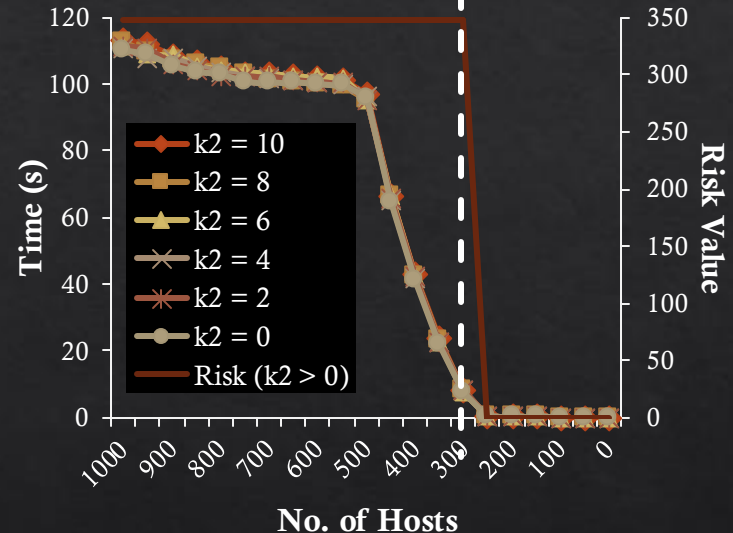
Simulation results

◇ Host based security analysis



Construction

(with k_2 number of vulnerabilities)



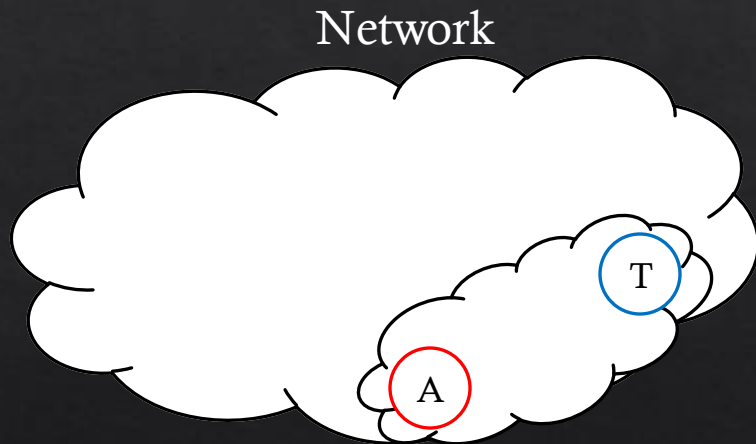
Evaluation

(with k_2 number of vulnerabilities)

The construction time linearly improves as the number of important hosts modeled reduce. For evaluation, there is a steady improvement until the host number reaches 500. From then, it rapidly improves the performance.

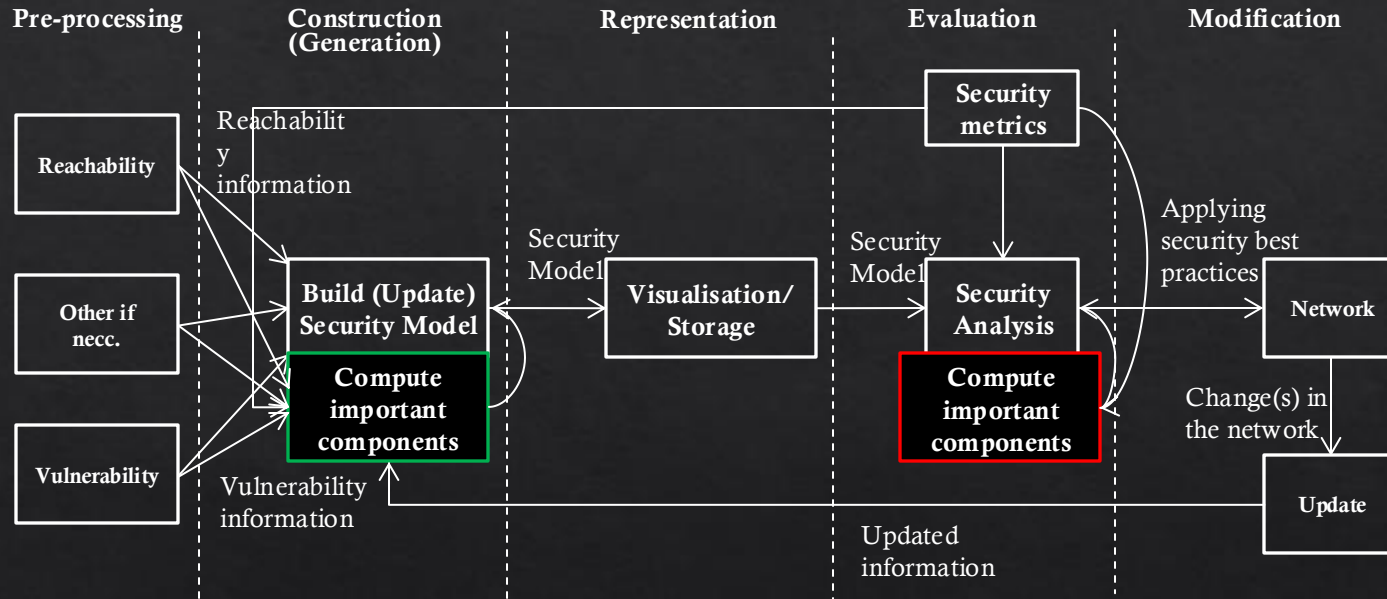
Network coverage

- ◆ Consider an attack scenario that covers only a subset of the network (e.g., an attacker located inside the network).



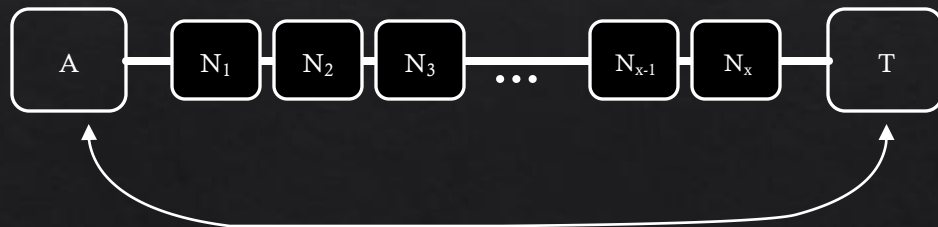
How to define the subnet covered by this attack scenario?

Recap – Lifecycle of Graphical Security Models



Attacker to Victim Centrality (AVC)

- Upper layer NCMs do **not** consider the place of the attacker and the target (victim).
- We define a location-based (Attacker to Victim) centrality (AVC) measurement based on **distance** measurements.



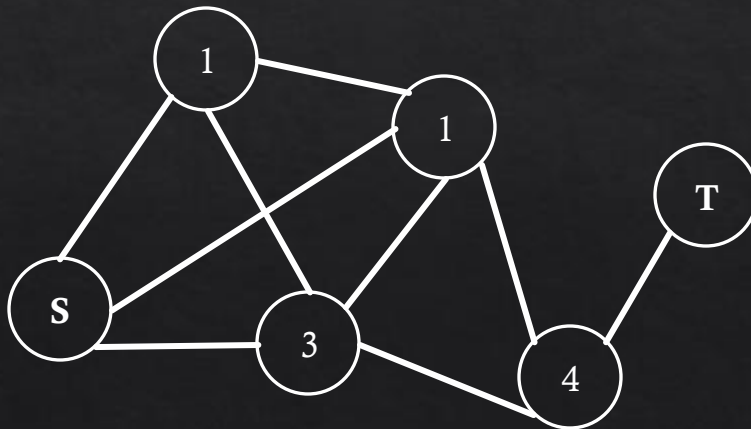
Measure distance between A and T

Attacker to Victim Centrality (AVC) (cont.)

- ◇ Ranking important hosts using location based centrality

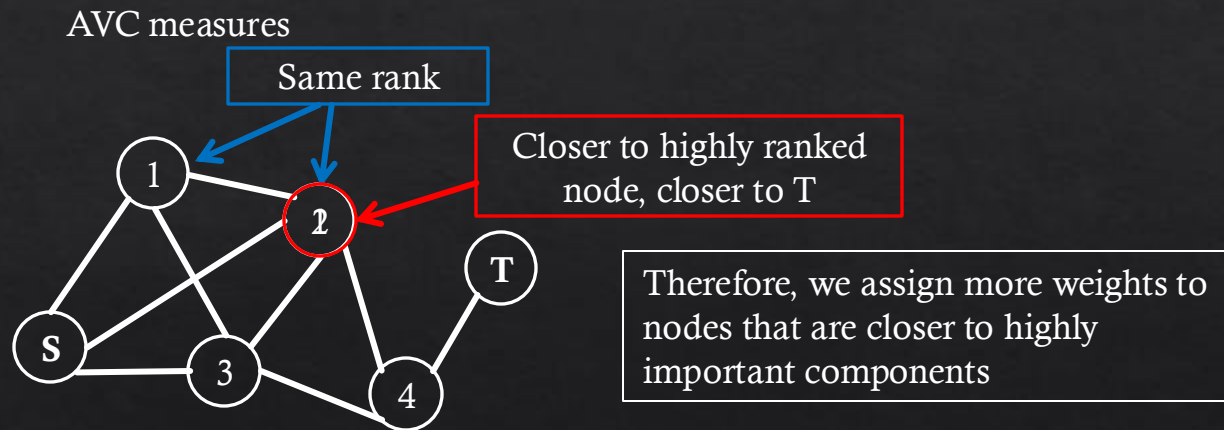
- ◇ Attacker to Victim Centrality (AVC)

- Importance measure based on the node **location**



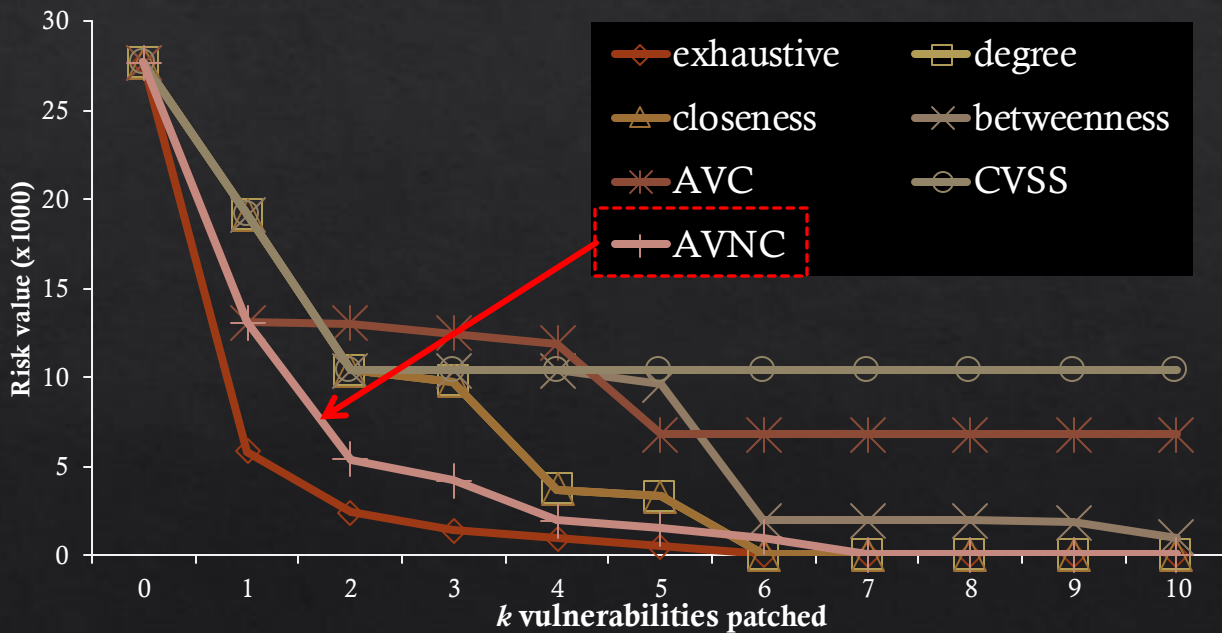
Attacker to Victim **Neighbour** Centrality (AVNC)

- ◇ If there are components with the **same** ranking, then the AVC may not identify important components correct.



Security Analysis via Simulation

◇ Results – multiple subnets, **internal** attacker



The location based centrality measure AVNC performs most closely to the exhaustive search.

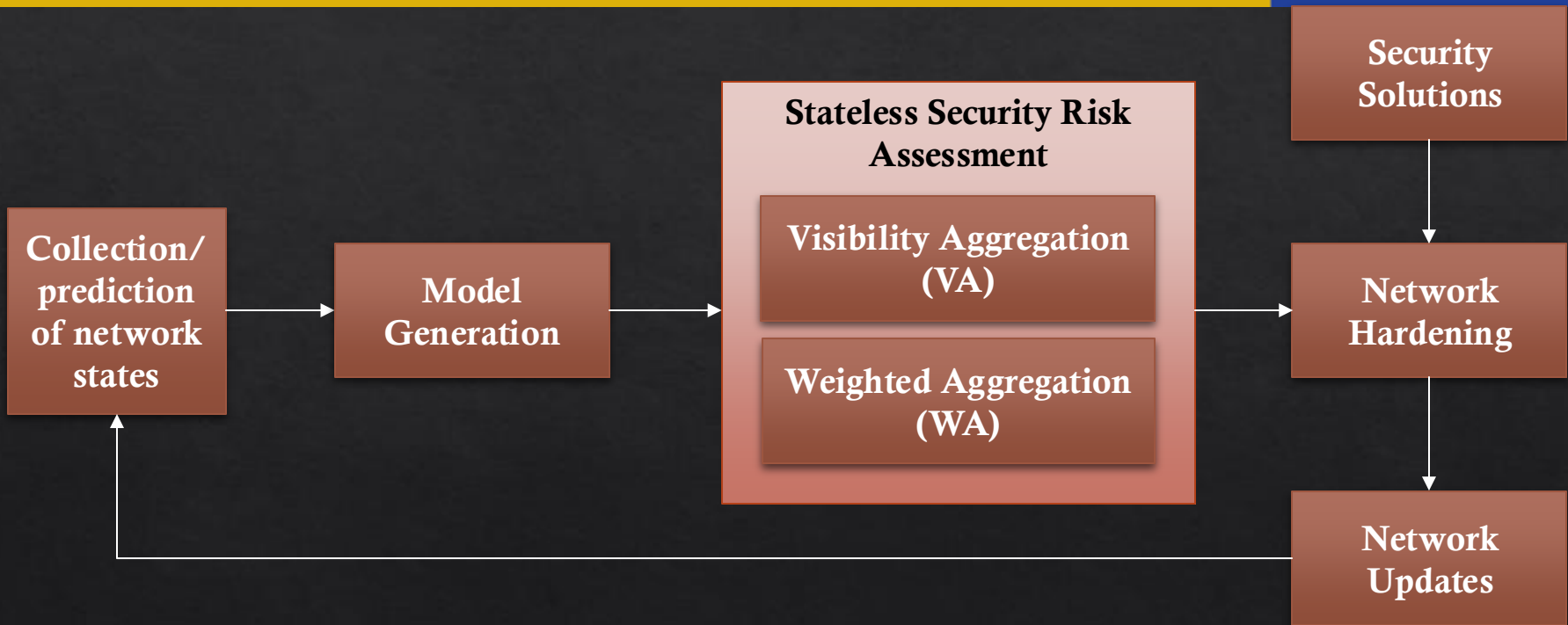
Limitations

- ◇ To address the dynamic adjustment issues
 - ◇ Capture dynamic changes using the model
 - ◇ E.g., use of temporal graphs
 - ◇ Real-time change detection mechanisms
 - ◇ E.g., real-time IDS, system logging etc...
 - ◇ Develop dynamic security metrics for evaluations
 - ◇ E.g., identifying persistent vulnerability etc...
- ◇ Anything else?

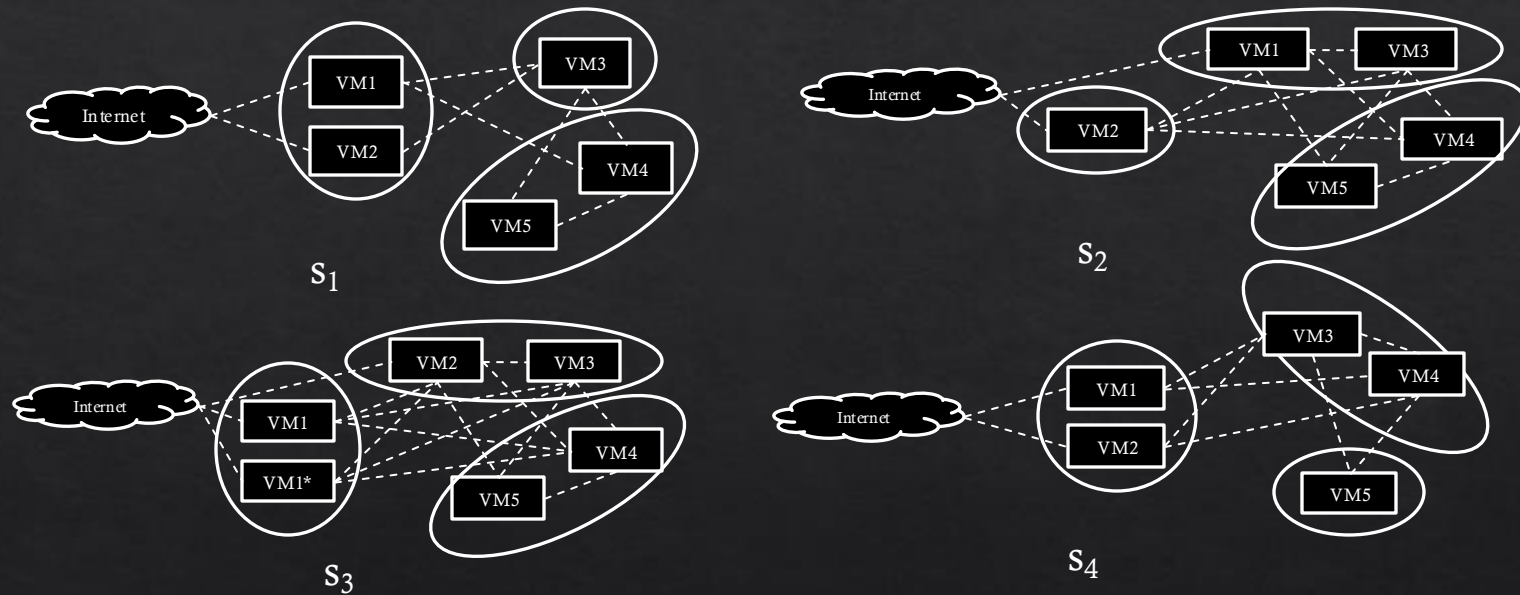
Proposed approach: stateless security risk assessment

- ◇ We propose “*stateless*” security risk assessment to capture the overall security posture of dynamic networks.
 - ◇ Since dynamic networks create different network states over time, we collect all the network state information over time.
- ◇ A *network state* refers to a specific network configuration and its component observed at the time.
- ◇ To provide the security overview for the whole period, we aggregate the observed network states using two approaches.
 - ◇ Visibility Aggregation (VA)
 - ◇ Weighted Aggregation (WA)

Proposed approach: stateless security risk assessment (cont.)



Example dynamic network



For example, we observe the following states

Time t_i	1	2	3	4	5	6	7	8	9	10
State s_i	s1	s1	s3	s1	s2	s2	s2	s1	s4	s4

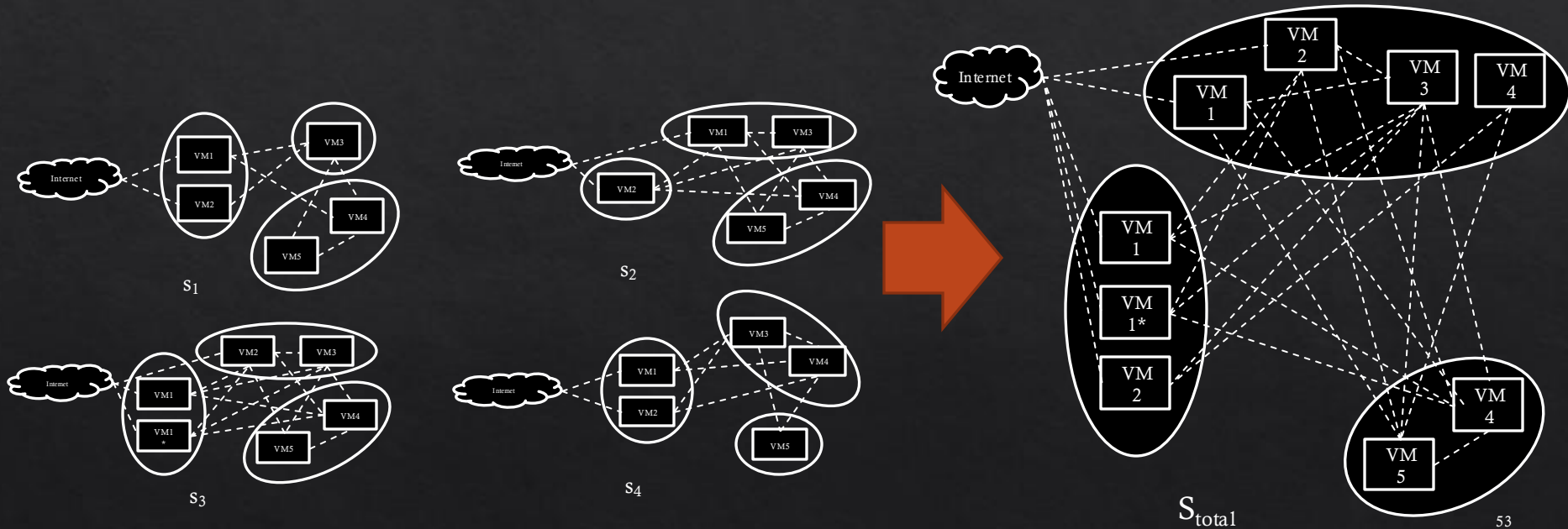
Visibility Aggregation (VA)

- ◇ All the observed network states are aggregated maintaining all the enabled configurations
 - ◇ e.g., host-to-host connections, running applications
- ◇ This collects all the potential security risk of the dynamic network
- ◇ Advantages
 - ◇ All network state information is represented
 - ◇ This risk value will not change unless the network/threat changes
- ◇ Disadvantage
 - ◇ Does not reflect the exposure of different states

```
S: a set of all network states;  
for  $s \in S$  do  
  | if components of  $s_i$  not in  $s_{init}$  then  
  |   |  $s_{init} = s_{init} \cup s_i$ ;  
  | end  
end  
Assess the security of  $s_{init}$ ;  
Algorithm 1: VA approach
```

Visibility Aggregation (VA) (cont.)

◇ We aggregate all the observed states



Perform security risk analysis of S_{total} .

Weighted Aggregation (WA)

- ◇ The weight factor is assigned to each observed network state based on the duration of exposure.
- ◇ Takes into account the exposure factor of each network state
- ◇ Advantages
 - ◇ All network state information is represented
 - ◇ Incorporate the exposure of different network states
- ◇ Disadvantage
 - ◇ Risk value may fluctuate based on the network behavior
 - ◇ e.g., exposure of network states change due to changing user behaviors

```
S: a set of all network states;  
ti: a time duration of si;  
T, the total duration of S;  
minit: a security metric to be computed;  
for s ∈ S do  
    | mi ← security assessment of si;  
    | minit = minit + (mi ×  $\frac{t_i}{T}$ );  
end  
return minit;
```

Algorithm 2: WA approach

Weighted Aggregation (cont.)

Weight = observed no. of states / total No. of states

◇ For the example dynamic network

	S₁	S₂	S₃	S₄	Total
Weight	0.4	0.3	0.1	0.2	1
Risk value*	100	130	80	50	-
Weighted risk value	40	39	8	10	97

Initial Experimental results

- ◇ We created a randomly generated network with a set number of hosts and edges between the hosts.
- ◇ Each host is assigned with an arbitrary number of vulnerabilities (1- 10) from the National Vulnerability Database (NVD)
- ◇ We implemented random **changes** in the generated network to make changes over time
 - ◇ Host addition/removal
 - ◇ Vulnerability addition/removal
 - ◇ Edge addition/removal
- ◇ We observed 8 network states for the evaluation

Initial Experimental results

Network States	Security Risk	WA	Vulnerability to patch
S ₁	42.8	5.8	V ₁₀
S ₁	104.3	11.4	V ₃
S ₁	67.4	6.5	V ₃
S ₁	91.9	11.4	V ₃
S ₁	122.4	15.4	V ₁₁
S ₁	90.7	29.5	V ₁₁
S ₁	90.7	29.5	V ₁₁
S ₁	90.7	29.5	V ₁₁
S _{init}	185.6	-	V ₁₁
sum	-	139.0	-

Optimal solution changes over time

More exposure, more risk

Patch this to reduce the VA Risk value the most (Reduces to 108.9)

VA Risk value

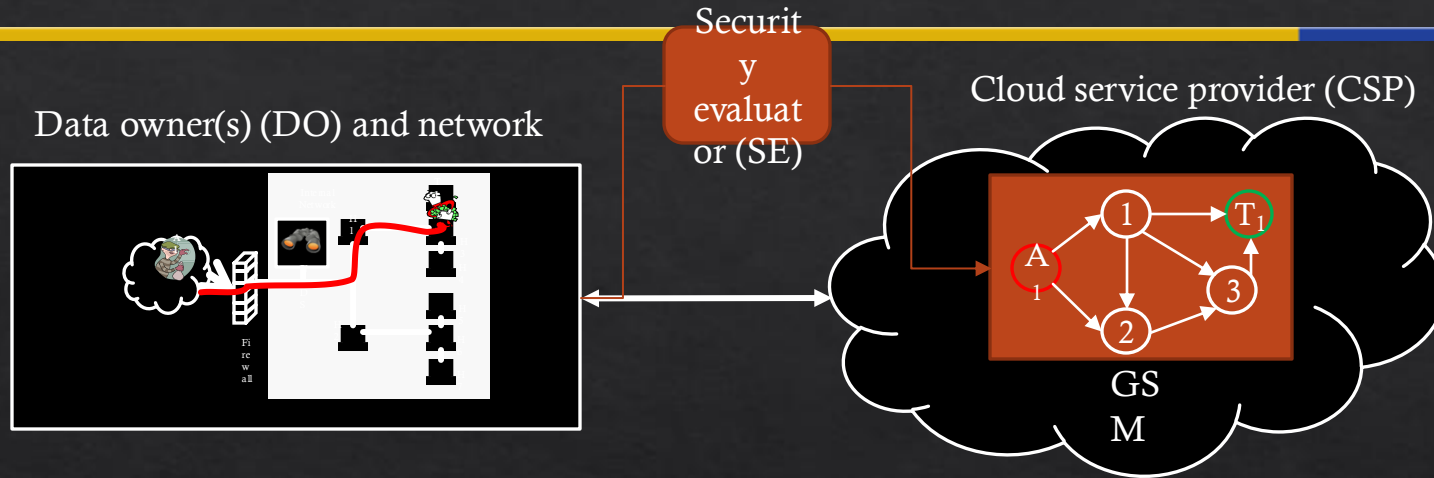
WA Risk value

Limitations

- ◇ To address the automation issues
 - ◇ Develop intelligent security analysis modules
 - ◇ E.g., use of AI, machine learning etc...
 - ◇ Pool of countermeasures for implementations
 - ◇ E.g., security awareness, easy security solution adoption methods etc...
 - ◇ Secure system architecture planning and implementation
 - ◇ E.g., security forecast, prediction, attacker profiling etc...
 - ◇ Anything else?

EDIT BELOW

Graphical Security Models (GSM) in cloud



◆ Problems

- ◆ Network related data collected centrally in cloud, this may cause privacy issue for the data owner
- ◆ Multi-users may access data
- ◆ Not all users may have privilege to access other's security data
- ◆ Storing security data at a single point can be a risk
- ◆ GSM processing in the cloud with current model can be a risk of information leak.

Privacy Preserving GSM (PPGSM)

- ◇ Encrypting security data does not preserve privacy
 - ◇ i.e. collected security info still related to users/nodes
 - ◇ We should adopt privacy preserving techniques
- ◇ Use privacy preserving techniques to collect security data
 - ◇ E.g. CP-ABKS – Robert Deng TDSC2019

Privacy Preserving GSM (PPGSM)

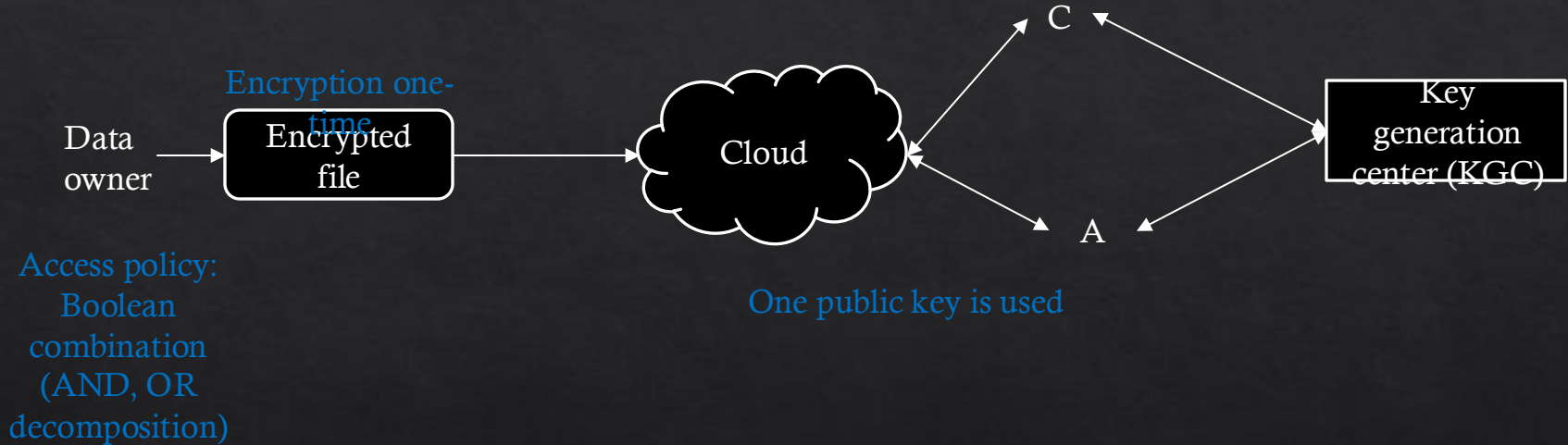
◆ Requirements

1. Security data should only be accessible by those who have authorisation (expressed as a set of attributes)
2. GSM should be able to process security data when it is encrypted

◆ Solution for 1 – Attribute-based Encryption (ABE)

- ◆ To enforce encryption to security data prior to collection and distribution.
- ◆ Ciphertext Policy ABE (CP-ABE) for distinguishing multiple users
 - ◆ Users include cloud provider, tenants, GSM etc.
- ◆ Security data encrypted sent to GSM in the cloud for processing

Ciphertext policy attribute-based encryption (CP-ABE)



Alice can decrypt the encrypted file if she has a public key and satisfy the access control.

Privacy Preserving GSM (PPGSM)

◆ Requirements

1. Security data should only be accessible by those who have authorisation (expressed as a set of attributes)
2. GSM should be able to process security data when it is encrypted

◆ Solution for 2 – Homomorphic Encryption (HE) (other alternatives)

- ◆ Homomorphic encryption allow processing of data on top of encrypted data
- ◆ Required for security data processing when GSM uses them for security evaluation

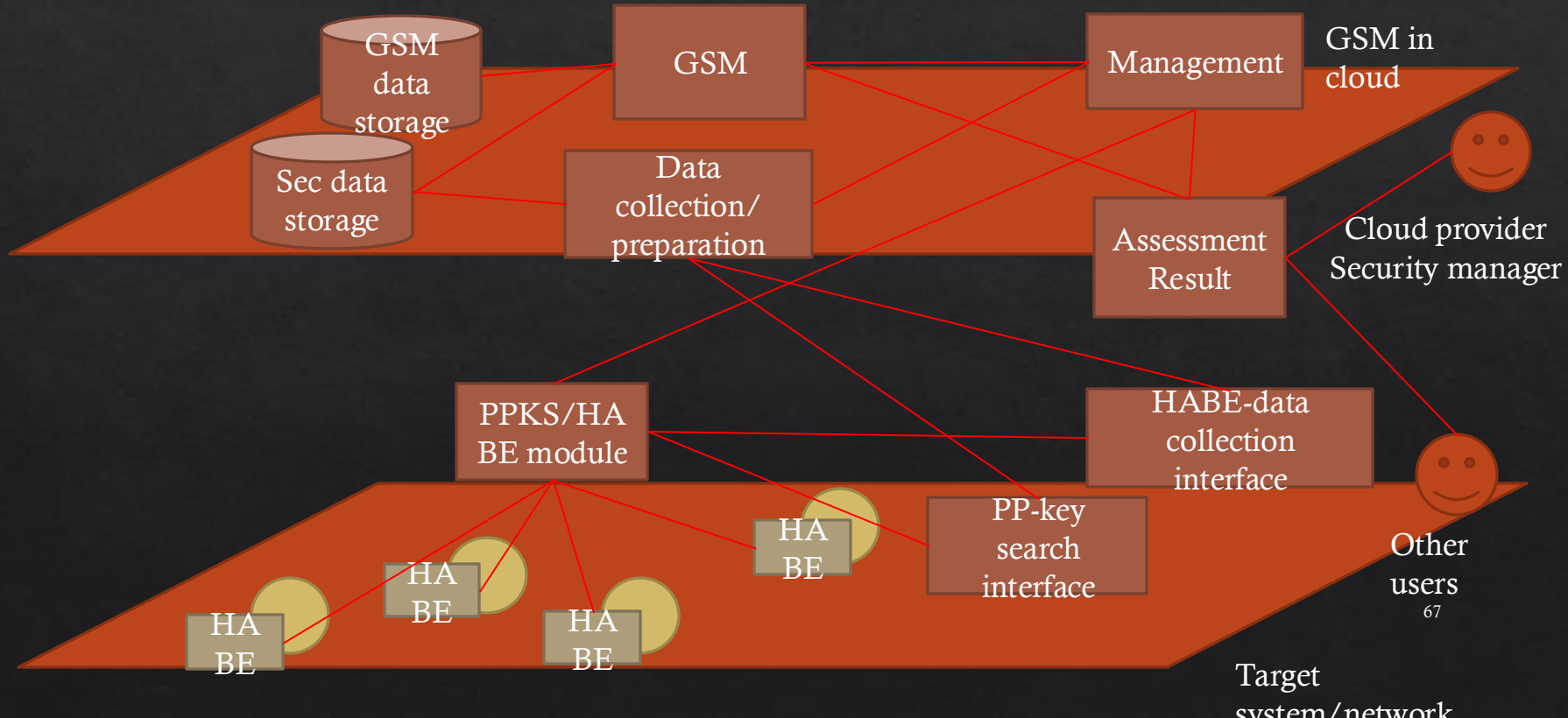
Secure computation

- ◆ 1. Fully homomorphic in 2019
 - ◆ Allows party B to computation data encrypted by party A
 - ◆ Currently 3rd generation
 - ◆ Still huge computation, huge computation cost, zero communication cost
- ◆ 2. Multiparty computation
 - ◆ First schemes in 1980's
 - ◆ Multi-parties jointly compute a function without learning other parties' input
 - ◆ Huge communication but almost zero computation
 - ◆ Modular, addition **in plaintext** are supported

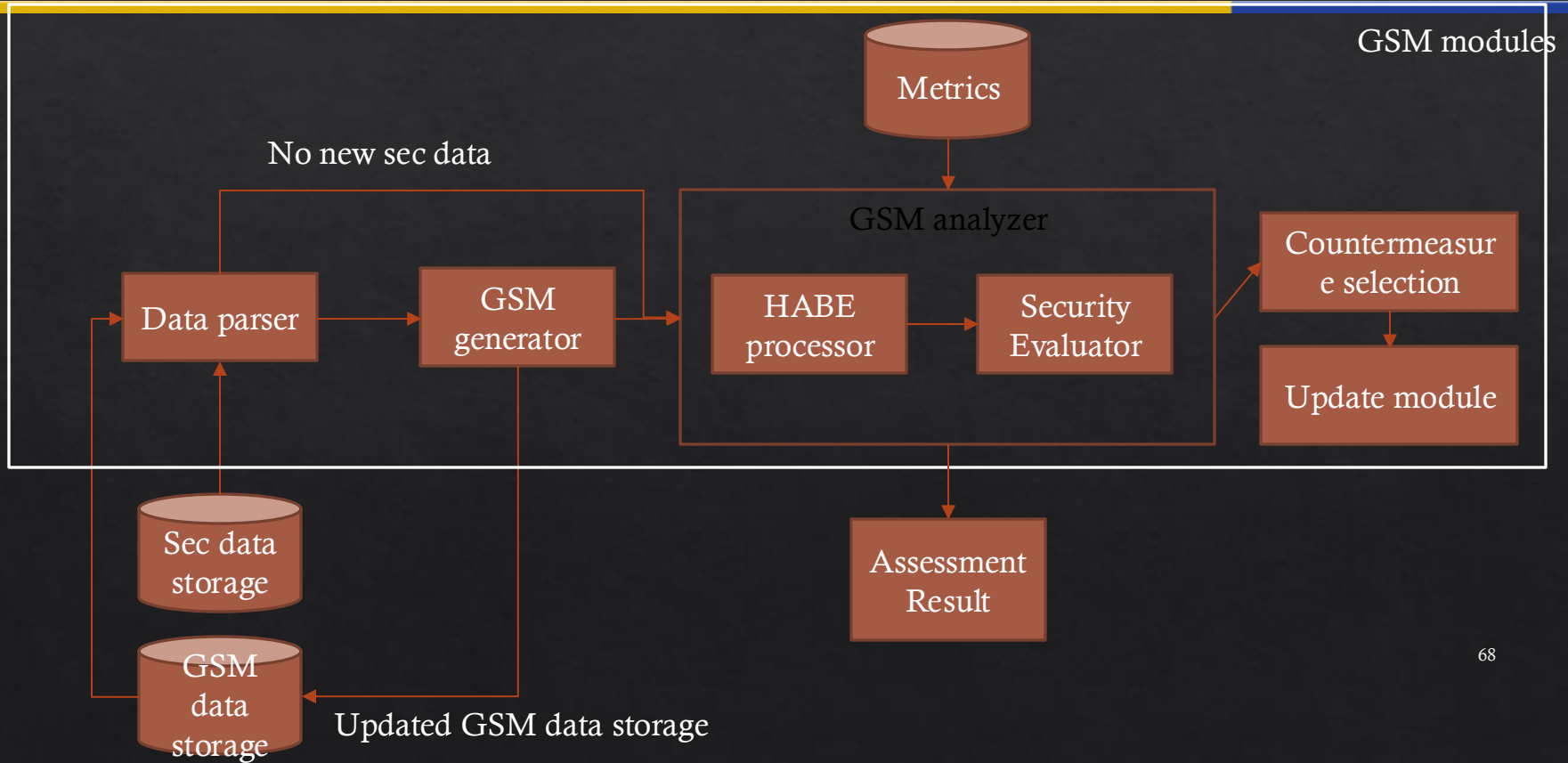
Privacy Preserving GSM (PPGSM)

- ◇ Challenge
 - ◇ How to combine ABE (or alternative) and HE (or alternative)
- ◇ Potential Solution: Homomorphic ABE (HABE) schemes
 - ◇ ABE from full key HE <https://eprint.iacr.org/2014/356.pdf>
 - ◇ Multi Target HABE <https://eprint.iacr.org/2016/691.pdf>
 - ◇ Dynamic Multi Target HABE <https://eprint.iacr.org/2017/373.pdf>

PP-GSM overview



PP-GSM overview – GSM process



GSM structure

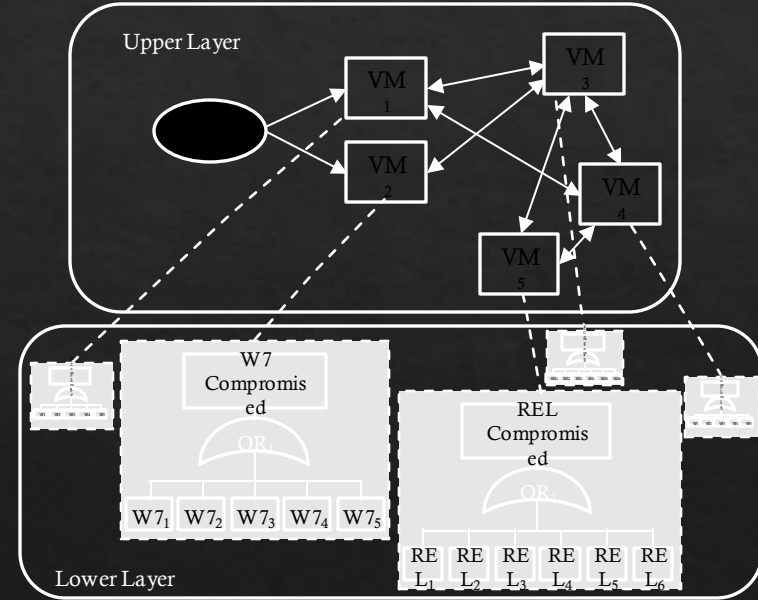
◇ Base model: HARM

Definition 1. The HARM has a 3-tuple $H = (h, M, C)$. h is the number of layers ($2 \leq h$). M is the set of all models used in each layer, $M_i \in M$ is a subset of models in M at i th layer, and $M_i^n \in M$ is a member of M at the i th layer linked to a node n in the $i - 1$ th layer. $C = n_i \leftrightarrow M_{i-1}^{n_i}$ is the set of all mappings between HARM components in two different layers, where $n_i \in M_i$ and $i \in h$.

Definition 2. An Attack Graph (AG) in the i th layer in the HARM is a directed graph $G^i = (N^i, E^i)$, where N^i is a finite set of components at the i th layer and $E^i \subseteq N^i \times N^i$ is a set of edges where a pair of network components (n_i, n_j) is a mapping of $n_i \rightarrow n_j$ with $n_i, n_j \in N$ and $i \neq j$.

Different structure can be used for different layers

Example 2-layered AG-AT HARM



GSM structure

- ◇ E.g. risk calculation
- ◇ Other calculation algorithms available.

```
1:  $HARM = \{h, M, C\}$ 
2: Risk  $R$ 
3: No. of Paths  $P$ 
4: procedure EVALUATE_HARM_RISK( $HARM$ )
5:   for  $i = 1 \dots h$  do
6:     for all  $m \in M_i$  do
7:        $R_m, P_m = \text{solve\_Risk}(m)$ 
8:        $R_{n_j} \leftarrow R_m \mid n_j \leftrightarrow M_i^{n_j} \in C$ 
9:        $P_{n_j} \leftarrow P_m \mid n_j \leftrightarrow M_i^{n_j} \in C$ 
10:    end for
11:  end for
12:  Return  $R_{M_h}, P_{M_h}$ 
13: end procedure
14:
15: procedure SOLVE_RISK( $m$ )
16:  Compute All Possible Attack Paths  $path$  of  $m$ 
17:   $R_m \leftarrow$  sum of risk in  $path$ 
18:   $P_m \leftarrow |path|$ 
19:  Return  $R_m, P_m$ 
20: end procedure
```

GSM structure – dynamic networks

◇ Base model: T-HARM

Definition 1. We define T-HARM for a dynamic network as a sequence of HARM snapshots $s_{t_0}, s_{t_1}, s_{t_2}, \dots, s_{t_n}$. Each snapshot is defined as a 3-tuple $S_{t_i} = (U_{t_i}, L_{t_i}, C_{t_i})$. Here, U_{t_i} is the AG and L_{t_i} is the ATs for H and V , respectively at t_i . Where, C_{t_i} is the mapping between the upper layer components and lower layer components. This mapping is described by $C_{t_i}: U_{t_i} \rightarrow L_{t_i}$. Each host in the upper layer may have a corresponding AT in the lower layer for all t_i .

Definition 2. A dynamic AG is defined as a directed graph $ag_{t_i} = (H, E)$ at time t_i , where H is a finite set of hosts and $E \subseteq H \times H$ is a set of edges which connects the hosts. Let K be a sequence of attacker's snapshots which include one or multiple attackers and $k \in K$ is a sequence of snapshots $k_{t_0}, k_{t_1}, \dots, k_{t_n}$, where n is the total number of snapshots, $K \notin S$ and $K_{hosts} \cap H = \emptyset$. The representation of U (the upper layer) is given by $U: H \subseteq S \cup K$ and $E \subseteq (S \cup K) \times S$.

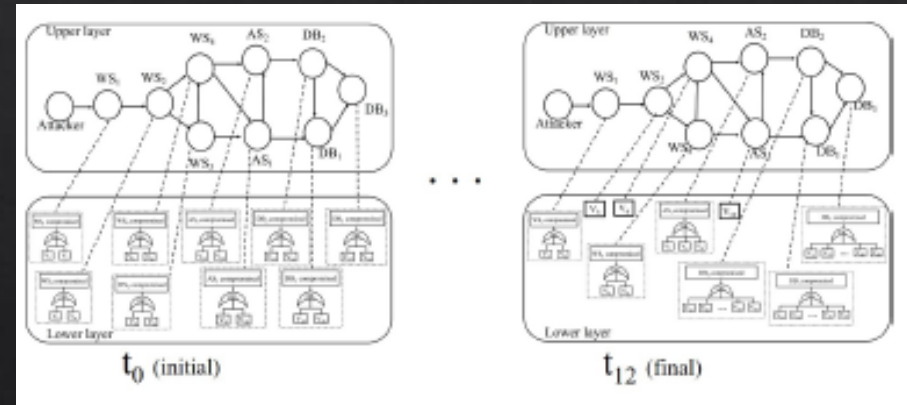
Definition 3. A dynamic AT is defined as a 5-tuple $at_{t_i} = (A, B, c, g, root)$ at time t_i . Here, A is a set of components which are the leaves of at_{t_i} and B is a set of gates which are the inner hosts of at_{t_i} . We require $A \cap B = \emptyset$ and $root \in A \cup B$. Function $c: B \rightarrow \mathcal{P}(A \cup B)$ describes the children of each inner host in at_i (we assume there are no cycles). Function $g: B \rightarrow \{AND, OR\}$ describes the type of each gate. The representation of the attack tree $at_{t_i}^h$ associated to the host $h \in H$ is as follows:

- $at_{t_i}^h: A \subseteq h_{vuls}$.

This means that the vulnerabilities of a host are combined using *AND* and *OR* gates.

GSM structure – dynamic networks

- ◇ HARM -> tree
- ◇ T-HARM -> forest



Questions

- ◇ What operation (computation) does a GSM require to calculate metrics?
 - ◇ Metrics: Set (set of vulnerabilities > severity value X), multiplication ($\text{Risk} = \text{prob} * \text{impact}$), path discovery (native, min, max, number), etc.
- ◇ Can we also hide topology information?
 - ◇ Node level security info encrypted, but what about higher level structure?
- ◇ Performance?
 - ◇ Introduction of HABE and PPKS can introduce significant overhead.
- ◇ Complex security assessment computations?
 - ◇ HABE provides simple arithmetic computations, will it support all security assessment computations?
 - ◇ Likely, if we break down security data into atomic items needing only simple computations

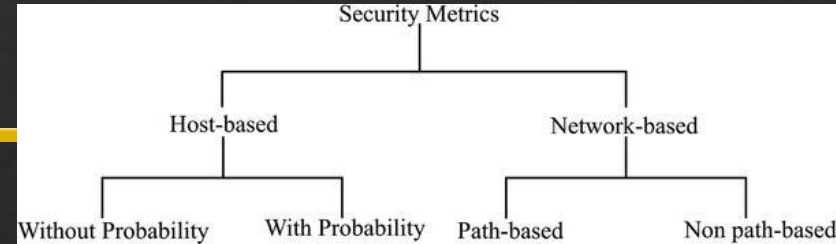
GSM operations

◇ Metric calculations used¹

- ◇ At a host level: Addition, multiplication
 - ◇ Probability, cost, time, return on attack etc.
- ◇ At a network level: path, addition, multiplication
 - ◇ Shortest attack path, mean attack path length, etc.
 - ◇ Risk, impact, cost etc.

◇ Later, dynamic security metrics²

- ◇ Modifying HARM object structure, or using T-HARM (or Ti-HARM)
 - ◇ Connections, properties of nodes, metric values etc.



2. Hong, J. and Yusuf, S. and Kim, D. and Nhlabatsi, A. and Fetais, N. and Khan, K.; "Dynamic Security Metrics for Measuring the Effectiveness of Moving Target Defense Techniques" Journal of Computers and Security, Elsevier, vol. 79, pp. 33-52, Nov 2018

PP techniques for calculations

- ◇ Existing techniques allowing PP techniques when whole graph is encrypted:
 - ◇ Some graph metric calculations
 - ◇ Centrality measures, shortest path, etc.
 - ◇ Basic arithmetic calculations
 - ◇ At node level, +, -, * etc.
 - ◇ Problem:
 - ◇ How to combine calculations, which are necessary for security metric calculations?
 - ◇ Soln1: develop new calculation steps to perform those tasks – SKKU input?
 - ◇ Problem with soln1: need to develop new calculation steps for each metric we want
 - ◇ May not be a big issue if metrics are limited, but should consider dynamic security metrics.
 - ◇ Soln2: do not encryption the whole graph, encrypt each graph component
 - ◇ Problem with soln2: network structure info not hidden
 - ◇ Soln for this problem: add null-information nodes
 - ◇ Still visible when encrypted
 - ◇ But not used in calculation steps when computing metrics
- CryptGraph: Privacy Preserving Graph Analytics on Encrypted Graph
 - Enabling Privacy-Preserving Shortest Distance
 - Queries on Encrypted Graph Data
 - Graph Encryption for Top-K Nearest
 - Keyword Search Queries on Cloud
 - etc

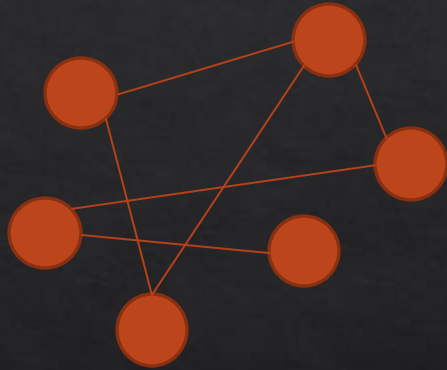
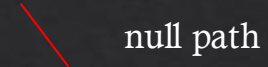
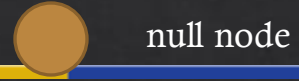
Soln1 previous work

- ◆ CryptGraph: Privacy Preserving Graph Analytics on Encrypted Graph
 - ◆ Encrypt graph using adjacency matrix
 - ◆ Query outputs are all Boolean
 - ◆ So we ask is i,j,k form a triangle $\rightarrow i,j$ connected AND j,k connected AND i,k connected
 - ◆ Could be useful for some metric calculations
 - ◆ E.g. ?
- ◆ Enabling Privacy-Preserving Shortest Distance Queries on Encrypted Graph Data
 - ◆ Calculates shortest distance queries
 - ◆ Not the actual graph is sent to cloud- encrypted index generated from secret key K and 2-hop cover labelling index
 - ◆ Would only be useful for determining the shortest distance
 - ◆ Many others are based on this approach
 - ◆ Generate the secure index by encrypting the graph
 - ◆ Send encrypted queries
 - ◆ Results (encrypted) sent back to the user

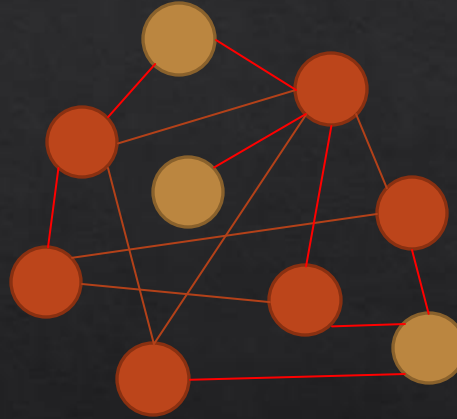
Soln1 approach

- ◇ Have to come up with some graph structure that can process queries related to calculating security metrics.
- ◇ Some path based approaches may be modified to generate paths of length x (i.e. query attack path length x , then put x in range 1 to $n-1$).
- ◇ Problem, how about lower layers with associated metric values
 - ◇ We want the cloud to process this, not the client.
 - ◇ Possibly, each layer HARM has its own security index for the graph, correlation map data is kept at the user-end.
 - ◇ Then, each graph depending on the layer, the query can differ to compute necessary info.
 - ◇ The raw computed data can be further processed in combinations
 - ◇ How?

Soln2 example



Step 1: gather
network data



Step 2: add null
node/paths

Step 3: encrypt network data
from step 2, and send to
cloud (individual network
component, connections,
details stored also)

PP-GSM features and usage

- ◇ PP-GSM provides the following features over non-PP GSMs
 - ◇ Security management/assessment/audit from different companies etc to access data at the given time/period.
 - ◇ Non-privileged users (e.g. tenants) to access only the relevant security information/data
 - ◇ Security data access can be granted without exposing sensitive user data (pp)
 - ◇ Different security assessors can evaluate using different metrics without accessing other security information
 - ◇ Cooperative data collection between cloud service provider and tenants
 - ◇ So we don't have the visibility problem, as tenants can share data while preserving privacy
 - ◇ Anything else?
 - ◇ Implementation issues

Summary

- ◇ There are **various** security standards and frameworks internationally accepted as a common practice
 - ◇ E.g., ISO and NIST security standards and frameworks
- ◇ They provide detailed **procedures** for organisations to follow, in order to assess the security posture of their systems
- ◇ Many steps are involved, so security administrators should ensure that each step is done **carefully and complete**
- ◇ Use of **automated tools** can speed up the process, as well as avoiding any human errors

Additional Items

◇ Security models

- ◇ Kordy, Barbara, Ludovic Piètre-Cambacédès, and Patrick Schweitzer. "DAG-based attack and defense modeling: Don't miss the forest for the attack trees." *Computer science review* 13 (2014): 1-38.
- ◇ Hong, Jin B., et al. "A survey on the usability and practical applications of graphical security models." *Computer Science Review* 26 (2017): 1-16.
- ◇ Visualisation (note: videos are not working): <https://visualisation.trespass-project.eu/>